

CPPG · 최신 기출문제 02회

오답노트 상세해설 · 보강본

사진 속 지문 · 선지 보존
정답과 오답을 모두 설명하는 STEP BY STEP 해설

40문항 · 5개 과목 분류 · 예랑이랑 통합본 연결 · 법령 오류 교정

검증 기준일 2026.08.16

사진 속 지문과 선지는 수정하지 않고 전사했습니다. 해설·정답은 2026.08.16 현재 시행 중인 법령과 공식 기준을 우선 합니다. 사진 해설과 현행 기준이 충돌하면 붉은 경고로 표시했습니다.

과목	총 문항	오답	정답	정답률
1과목 개인정보보호의 이해	10	5	5	50.0%
2과목 개인정보 보호 제도	20	8	12	60.0%
3과목 개인정보 라이프사이클 관리	25	13	12	48.0%
4과목 개인정보 보호조치	30	10	20	66.7%
5과목 개인정보 관리체계	15	4	11	73.3%
전체	100	40	60	60.0%

우선순위: 3과목(정답률 48.0%) → 1과목(50.0%) → 2과목(60.0%). 4·5과목은 상대적으로 높지만 접속기록·CPO 직급처럼 시행일·숫자 함정이 있어 정밀 복습이 필요합니다.

- Q41: 소비자 불만·분쟁처리 기록은 3년이 맞아 정답 선지가 없습니다.
- Q48: ① 외에 ③의 'ISMS-P 자동 국외이전 면제' 표현도 부정확해 복수 오답 위험이 있습니다.
- Q57: 2026.7.1 시행 고시 기준으로 '월 1회' 고정주기는 삭제되어 제공 정답 ①이 성립합니다.
- Q59: 사진에는 있으나 입력 목록에서 누락되었습니다. 과목별 오답 합계에 맞춰 포함했습니다.
- Q96: ③이 아니라 ⑤가 틀린 선지입니다. 시·도와 시·도 교육청의 CPO 기준은 3급 이상입니다.

목차

1과목	6
Q1. 스트리밍 플랫폼 Alpha는 2025년 신작 공개를 앞두고, 시청 이력·재생 위치·정지...	7
Q2. 다음은 한 기업에서 개인정보 처리 원칙을 토론하는 내용이다. 이 대화의 취지에 가장 부...	9
Q3. 2025년 해외 공항에서 발생한 바이오 정보 유출 사고가 발생한 이후, 국내 온라인 커...	11
Q4. 다음 중 EU GDPR에서 사용하는 용어 정의에 대한 설명으로 옳지 않은 것은	13
Q9. 다음의 보기중 용어에 대한 설명으로 가장 적절하지 않은 것을 고르시오.	15
2과목	17
Q13. 다음 중 「개인정보 보호법」 제4조에 규정된 정보주체의 권리에 해당하지 않는 것은	18
Q15. 다음 중 「개인정보 보호법」 상 ‘민감정보’ 처리에 관한 설명으로 가장 부적절한 것은	20
Q16. 「개인정보 보호법」 제16조(개인정보의 수집 제한)의 ‘필요 최소한의 수집’ 원칙을 가...	22
Q21. 다음 중 「개인정보 보호법」 제31조에 따라 개인정보 보호책임자(CPO)가 반드시 수행...	24
Q22. 개인정보처리자가 공개해야 하는 ‘개인정보 처리방침’ 필수 항목을 점검하려 한다. 다음 ...	26
Q23. B은행은 고객 C씨가 대출 사기를 당했다는 이유로 수사기관의 ‘전화 한 통’만으로 C씨...	28
Q28. 배달 플랫폼 E사는 라이더의 실시간 위치 정보를 광고주에게 제공해 서비스 품질 분석에 ...	30
Q30. 다음 중 단체소송에 대한 설명으로 가장 적절하지 않은 것을 고르시오.	32
3과목	34
Q32. A기관이 ‘가명정보’를 활용한 통계·연구 과제를 추진하면서 개인정보처리방침 개정을 준비...	35
Q35. 개인정보 파기 원칙에 대한 설명으로 틀린 것은	37
Q36. 개인정보처리자는 개인정보 수집·이용 시 정보주체에게 법령에서 정한 사항을 고지하여야 한...	39
Q40. 영리 목적의 광고성 정보 전송 제한에 대한 설명으로 적절하지 않은 것을 고르시오.	41
Q41. 개인정보처리자는 다른 법령에 근거하여 개인정보를 보존해야 하는 경우에는 파기하지 않고 ...	43

Q45. 다음 중 제3자에 해당하는 보기로 묶인 것을 고르시오.	45
Q46. 모바일 간편결제 서비스 K는 회원가입 과정에서 다음 4개 항목 ① 수집 목적 ② 수집	47
Q48. 개인정보의 국외이전에 대한 설명으로 적절하지 않은 것을 고르시오.	49
Q49. 개인정보의 국외이전을 위해 정보주체에게 별도 동의를 받을 때 고지사항으로 적절하지 않은	51
Q50. 개인정보 수집 출처 및 이용·제공 내역 통지에 대한 설명으로 적절하지 않은 것을 고르시	53
Q51. 정보주체 이외로부터 수집한 개인정보 통지 의무 개인정보처리자 요건으로 적절한 것을 고르	55
Q52. 개인정보처리자는 정보주체로부터 적법하게 동의받기 위해서는 동의 조건을 모두 충족하여야	57
Q53. 개인정보처리자는 정보주체의 서면 동의를 통해 개인정보를 수집하려는 경우는 대통령령으로	59

4과목

61

Q57. 개인정보의 안전성 확보조치에 따른 ‘접속기록의 보관·점검’에 대한 설명으로 적절한 것을	62
Q59. 접근권한 관리에 관한 다음 설명 중 가장 적절하지 않은 것은	64
Q61. 「개인정보의 안전성 확보조치 기준 고시」에 따른 ‘내부관리계획’ 필수 항목으로 옳지 않	66
Q62. 다음 중 개인정보처리시스템 ‘접속기록’의 필수 기재사항이 아닌 것은	68
Q66. 다음 중 「개인정보의 안전성 확보조치 기준」 제6조(접근통제)에 따라 원격 접속 시 적	70
Q67. 다음 중 내부관리계획에 대한 설명으로 옳지 않은 것은 무엇인가	72
Q69. 개인정보 유·노출 방지 조치를 위한 예시로 적절하지 않은 것을 고르시오.	74
Q73. 개인정보 암호화 알고리즘 선택 기준에 따라 가장 부적절한 것은	76
Q78. 다음 중 SSL과 응용 프로그램 보안 처리 방법에 대한 설명으로 적절하지 않은 것은 무	78
Q84. DRM(Digital Rights Management)과 DLP(Data Loss Pr	80

5과목

82

Q89. 다음 중 정보보호 및 개인정보보호 관리체계 인증(ISMS-P)을 취득할 때, 인증심사의	83
Q92. 개인위치정보의 이용 또는 제공에 관한 설명으로 적절하지 않은 것을 고르시오.	85
Q96. 개인정보보호법 제31조제1항에 따른 개인정보 보호책임자 지정에 대한 설명으로 적절하지	87

Q97. 정보보호 및 개인정보보호 관리체계 인증(ISMS-P) 의무 대상자에 대한 설명으로 적절... 89

1과목

개인정보보호의 이해

개념 · GDPR · 가명정보

오답 5/10문항 · 정답률 50.0%

수록 문항: Q1, Q2, Q3, Q4, Q9

이 과목은 문장 속 ‘원칙·예외·기준일·주체’를 먼저 표시한 뒤 선지를 판정하세요.

Q1. 스트리밍 플랫폼 Alpha는 2025년 신작 공개를 앞두고, 시청 이력·재생 위치·정지...

정답 결론

제공 정답: ② | 검증 결론: ②(가장 적절)

사진 원문 · 지문과 선지

스트리밍 플랫폼 Alpha는 2025년 신작 공개를 앞두고, 시청 이력·재생 위치·정지 장면 데이터를 학습시켜 ‘몰입 구간 예측 AI’를 개발하려 한다. Alpha는 ‘콘텐츠 추천 품질 향상’을 목적으로 시청자 150만 명의 비식별화 데이터를 미국 리전 GPU 팜으로 전송·학습하고, 결과 모델을 역으로 한국 서비스에 적용할 계획이다. 이때 「개인정보 보호법」, GDPR, ISO/IEC 27701을 함께 고려할 때 가장 적절한 조치는?

- ① 완전 익명화가 불가능하므로 학습 데이터 전송 자체를 포기한다.
- ② 시청 이력에 대한 정보주체 개별 동의, 가명처리, 전송·학습, 전송이력 3년 이상 보관한다.
- ③ ‘콘텐츠 추천’은 정당한 이익이므로 동의 없이 전송·학습 가능하다.
- ④ AI 학습은 통계 목적이므로 가명처리 없이 전송·학습한다.
- ⑤ 한국 서버에서 학습 후 모델 파라미터만 미국으로 전송하면 역외 이전이 아니다.

STEP BY STEP

- 1 시청 이력·재생 위치·정지 장면은 이용자를 식별하거나 추정할 수 있어 개인정보가 될 수 있다.
- 2 미국 리전에서 저장·조회·학습하면 국외 제공·처리위탁·보관 중 하나에 해당할 수 있으므로 국외이전 근거와 고지가 필요하다.
- 3 AI 학습 목적은 원래 수집 목적과의 관련성, 예측 가능성, 정보주체 불이익, 가명처리 등 안전조치를 함께 심사해야 한다.
- 4 따라서 별도 동의 또는 다른 적법한 국외이전 근거를 확보하고, 가명처리·접근통제·재식별 금지·보유기간·삭제 및 전송 기록을 계약과 관리체계에 남기는 ②가 가장 보수적이다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	오답 - 익명화가 어렵다는 이유만으로 처리가 전면 금지되는 것은 아니다. 가명처리와 적법 근거, 위험통제로 진행할 수 있다.
②	정답 - 동의, 가명처리, 국외 전송·학습 통제, 기록관리라는 핵심 요소를 함께 제시한다. 다만 ‘3년’은 모든 AI 국외이전에 일률적으로 적용되는 단일 기간이라기보다 내부·계약상 보존기준과 관련 규정을 함께 확인해야 한다.
③	오답 - 정당한 이익은 자동 면허가 아니다. 특히 대규모 행동 데이터의 국외 AI 학습은 이익형량과 투명성·거부권·안전조치가 필요하다.
④	오답 - 통계·연구 목적이라도 가명정보 특례를 쓰려면 실제 가명처리와 재식별 방지조치가 전제된다.
⑤	오답 - 모델 파라미터도 학습정보를 기억·노출해 개인을 추론할 수 있으면 개인정보 판단 대상이 될 수 있다. ‘모델만 전송’이라는 형식만으로 국외이전을 배제할 수 없다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.22~23, p.47~48, p.61, p.67~70

AI 데이터 흐름을 ‘수집 → 가명처리 → 국외이전 근거 → 수령자 통제 → 학습 → 모델 반출 → 삭제’로 나누어 본다.
GDPR도 가명처리를 익명화와 동일하게 보지 않으므로, 가명 데이터에도 개인정보 규율이 계속 적용될 수 있다.

시험장 한 줄 암기

AI라고 예외가 되는 것이 아니라, 목적·근거·국외이전·가명처리·재식별 위험을 차례로 확인한다.

사진 출처: KakaoTalk_20260816_193019717.jpg

Q2. 다음은 한 기업에서 개인정보 처리 원칙을 토론하는 내용이다. 이 대화의 취지에 가장 부...

정답 결론

제공 정답: ③ | 검증 결론: ③

사진 원문 · 지문과 선지

다음은 한 기업에서 개인정보 처리 원칙을 토론하는 내용이다. 이 대화의 취지에 가장 부합하는 개념은 무엇인가?

위원장: “사생활 침해를 최소화해야 한다는 요구와, 개인이 자신의 정보를 스스로 통제하도록 보장해야 한다는 요구는 같은 의미인가? 다른 의미인가?”

법무팀: “전자는 주로 국가·기업의 간섭으로부터의 자유를 의미하고, 후자는 정보 흐름 전반에서의 ‘적극적 통제’를 말합니다.”

정보보호팀: “최근 판례는 두 권리를 상호 보완적으로 보지만, 핵심 개념은 분명히 구분됩니다.”

- ① 프라이버시권은 적극적 권리, 개인정보 자기결정권은 소극적 권리이다.
- ② 프라이버시권은 정보 통제권을 핵심으로 하는 적극적 권리이다.
- ③ 개인정보 자기결정권은 정보주체가 자신의 개인정보 처리 여부·방식을 스스로 결정하는 적극적 권리이다.
- ④ 두 권리는 동일한 개념으로 구분되지 않는다.
- ⑤ 프라이버시권은 2025년 개정법에서 처음 도입된 개념이다.

STEP BY STEP

- 1 프라이버시권은 전통적으로 사생활 영역에 함부로 들어오지 말라는 ‘간섭 배제’ 성격이 강하다.
- 2 개인정보 자기결정권은 개인정보가 언제, 누구에게, 어떤 목적으로 처리되는지 정보주체가 관여하는 권리이다.
- 3 따라서 대화에서 말한 ‘정보 흐름 전반의 적극적 통제’는 개인정보 자기결정권을 가리킨다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	오답 - 권리의 적극·소극 성격을 거꾸로 설명했다.
②	오답 - 정보 통제권을 핵심으로 하는 쪽은 개인정보 자기결정권이다.
③	정답 - 처리 여부와 처리 방식을 스스로 결정·통제한다는 핵심을 정확히 설명한다.
④	오답 - 두 권리는 서로 관련되지만 개념과 보호 초점이 완전히 같지는 않다.
⑤	오답 - 프라이버시권은 2025년에 처음 생긴 권리가 아니다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.4~6, p.17~20

시험에서는 ‘혼자 있을 권리·사생활 비밀’이 나오면 프라이버시권, ‘수집·이용·제공·삭제에 관여’가 나오면 개인정보 자기결정권으로 구분한다.

시험장 한 줄 암기

프라이버시 = 간섭받지 않을 자유, 자기결정권 = 내 정보 흐름을 결정할 권리.

사진 출처: KakaoTalk_20260816_193019717_01.jpg

Q3. 2025년 해외 공항에서 발생한 바이오 정보 유출 사고가 발생한 이후, 국내 온라인 커...

정답 결론

제공 정답: ⑤ | 검증 결론: ⑤

사진 원문 · 지문과 선지

2025년 해외 공항에서 발생한 바이오 정보 유출 사고가 발생한 이후, 국내 온라인 커뮤니티에서는 “바이오 정보는 한번 유출되면 영구적으로 위험하다”라는 주장이 확산되었다. 개인정보 가치산정 관점에서 이 주장의 타당성을 평가할 때 고려해야 할 요소로 가장 적절하지 않은 것을 고르시오.

- ① 대체 가능성(재발급·변경 가능 여부)
- ② 경제적 손실 추정(피해 회피 비용, 지불의사액)
- ③ 사회적 파급력(집단적 침해 가능성)
- ④ 기술 발전 속도(위험 감소·증대에 미치는 영향)
- ⑤ 개인정보 수집·보유 주체의 매출 규모

STEP BY STEP

- 1 가치산정은 정보 자체의 희소성·대체 가능성·민감성·위험 지속기간을 본다.
- 2 유출로 생기는 경제적 피해와 사회적 파급, 기술 변화로 위험이 커지거나 줄어드는지도 평가한다.
- 3 보유 기업의 매출은 제재액이나 배상능력과 관계될 수 있지만, 바이오 정보 자체의 가치·위험을 직접 정하는 요소는 아니다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 비밀번호와 달리 지문·홍채는 쉽게 바꿀 수 없어 위험이 장기화될 수 있다.
②	맞음 - 복구·보호 비용과 피해 회피를 위한 지불의사액은 경제적 가치 평가에 쓰인다.
③	맞음 - 대규모 인증체계에서 같은 유형의 정보가 악용되면 집단 피해가 가능하다.
④	맞음 - 스푸핑 탐지·취소 가능한 생체 템플릿 같은 기술은 위험 수준을 바꾼다.
⑤	오답(정답 선지) - 기업 매출은 정보의 고유한 가치와 직접적인 산정 요소가 아니다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.6~11, p.45~48

바이오 정보의 핵심은 ‘변경 곤란성’이다. 원본 이미지 대신 특징점을 변환한 템플릿을 저장하고, 유출 시 폐기·재발급 가능한 구조를 설계해야 한다.

시험장 한 줄 암기

정보가치 = 정보 특성 + 경제적 손실 + 사회·기술 환경. 회사 매출은 별개.

사진 출처: KakaoTalk_20260816_193019717_02.jpg

Q4. 다음 중 EU GDPR에서 사용하는 용어 정의에 대한 설명으로 옳지 않은 것은

정답 결론

제공 정답: ⑤ | 검증 결론: ⑤

사진 원문 · 지문과 선지

다음 중 EU GDPR에서 사용하는 용어 정의에 대한 설명으로 옳지 않은 것은?

- ① 정보사회서비스(Information Society Service)란 서비스를 제공받는 자의 개별적 요청에 따라, 온라인에서 전자적 수단을 통해 영리 목적으로 제공되는 서비스를 의미한다.
- ② DPO(Data Protection Officer)가 되기 위해 별도의 자격증이 필요하지 않으며, 반드시 해당 조직의 내부인일 필요는 없으며 외부 전문가를 선임해도 된다.
- ③ 프로파일링(Profiling)이란 개인의 특징을 분석하거나 예측하는 등 해당 개인의 특성을 평가하기 위하여 행해지는 모든 형태의 '자동화된(automatic)' 개인정보 처리를 의미한다.
- ④ 컨트롤러(Controller)란 개인정보 처리의 목적과 수단을 결정하는 주체를 말한다.
- ⑤ 개인정보(Personal data)란 살아 있는 개인에 관한 정보로서, 해당 정보만으로 또는 다른 정보와 결합하여 특정 개인을 식별할 수 있는 정보를 말한다.

STEP BY STEP

- 1 GDPR의 personal data는 '식별되었거나 식별 가능한 자연인'과 관련된 모든 정보를 말한다.
- 2 국내법 표현인 '해당 정보만으로 또는 다른 정보와 쉽게 결합하여 알아볼 수 있는 정보'와 문구가 다르다.
- 3 ⑤는 국내 개인정보 보호법식 정의를 GDPR 정의라고 제시했으므로 옳지 않다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 개별 요청, 원격·전자적 수단, 통상 보수를 받고 제공되는 서비스라는 요소를 설명한다.
②	맞음 - DPO는 직원일 수도 있고 서비스 계약에 따른 외부 전문가일 수도 있다.
③	맞음 - 프로파일링은 자연인의 특성을 평가·예측하는 자동화된 개인정보 처리다.
④	맞음 - controller는 처리 목적과 수단을 단독 또는 공동으로 결정한다.
⑤	오답(정답 선지) - 국내법식 문구에 가깝다. GDPR은 식별되었거나 식별 가능한 자연인과 관련된 모든 정보라는 더 넓은 구조를 쓴다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.39~46

GDPR 문제는 controller-processor, DPO, profiling, data subject 용어를 한 묶음으로 정리한다. ‘살아 있는 개인’이라는 점은 맞아도 전체 정의 문구가 어느 법 체계인지 확인해야 한다.

시험장 한 줄 암기

GDPR 개인정보 = identified or identifiable natural person과 관련된 모든 정보.

사진 출처: KakaoTalk_20260816_193019717_03.jpg

Q9. 다음의 보기중 용어에 대한 설명으로 가장 적절하지 않은 것을 고르시오.

정답 결론

제공 정답: ⑤ | 검증 결론: ⑤

사진 원문 · 지문과 선지

다음의 보기중 용어에 대한 설명으로 가장 적절하지 않은 것을 고르시오.

- ① 결합정보 : 결합전문기관을 통해 결합대상정보를 결합하여 생성된 정보
- ② 가명처리 : 개인정보의 일부를 삭제하거나 일부 또는 전부를 대체하는 등의 방법으로 추가정보가 없이는 특정 개인을 알아볼 수 없도록 처리하는 것
- ③ 추가정보 : 개인정보의 전부 또는 일부를 대체하는 가명처리 과정에서 생성 또는 사용된 정보로서 특정 개인을 알아보기 위하여 사용·결합될 수 있는 정보
- ④ 재식별 : 특정 개인을 알아볼 수 없도록 처리한 가명정보에서 특정 개인을 알아보는 것
- ⑤ 결합키 : 처리되는 정보에 의하여 알아볼 수 있는 사람으로서 그 정보의 주체가 되는 사람

STEP BY STEP

- 1 ①~④는 가명정보 결합과 재식별 과정의 용어다.
- 2 결합키는 서로 다른 정보집합의 동일 대상을 매칭하기 위한 값 또는 이를 변환한 식별자다.
- 3 ⑤의 설명은 결합키가 아니라 ‘정보주체’에 대한 설명이므로 틀렸다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 결합전문기관에서 결합 후 생성된 결과정보를 가리킨다.
②	맞음 - 추가정보 없이는 특정 개인을 알아볼 수 없게 만드는 처리를 설명한다.
③	맞음 - 가명처리 시 생성·사용되며 재식별에 쓰일 수 있는 별도 정보를 말한다.
④	맞음 - 가명정보에서 특정 개인을 다시 알아보는 행위다.
⑤	오답(정답 선지) - 정보주체의 정의를 결합키 정의로 잘못 붙였다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.47~50, p.53~54

결합키는 두 데이터셋을 연결하는 기술적 매칭 값이고, 정보주체는 그 정보가 가리키는 사람이다. 추가정보와 결합키는 접근권한을 분리하고 별도로 보관해야 한다.

시험장 한 줄 암기
결합키는 사람 자체가 아니라 데이터셋을 맞추는 값이다.

사진 출처: KakaoTalk_20260816_193019717_04.jpg

2과목

개인정보 보호 제도

권리·CPO·제3자 제공

오답 8/20문항 · 정답률 60.0%

수록 문항: Q13, Q15, Q16, Q21, Q22, Q23, Q28, Q30

이 과목은 문장 속 ‘원칙·예외·기준일·주체’를 먼저 표시한 뒤 선지를 판정하세요.

Q13. 다음 중 「개인정보 보호법」 제4조에 규정된 정보주체의 권리에 해당하지 않는 것은

정답 결론

제공 정답: ⑤ | 검증 결론: ⑤

사진 원문 · 지문과 선지

다음 중 「개인정보 보호법」 제4조에 규정된 정보주체의 권리에 해당하지 않는 것은?

- ① 개인정보 처리 여부 확인 및 열람 요구권
- ② 개인정보 처리 정지·정정·삭제 요구권
- ③ 개인정보 전송 요구권
- ④ 완전히 자동화된 결정에 대한 거부 또는 설명 요구권
- ⑤ 가명정보에 대한 열람·처리 정지·삭제 요구권

STEP BY STEP

- 1 법 제4조는 처리정보 제공, 동의 여부·범위 선택, 확인·열람, 정정·삭제·처리정지, 피해구제 등의 권리를 둔다.
- 2 전송요구권과 자동화된 결정 관련 권리는 개정법에서 구체화되었다.
- 3 하지만 가명정보는 재식별 방지를 위해 열람·정정·삭제·처리정지 등 일부 권리 조항의 적용이 배제된다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 정보주체의 대표적 권리다.
②	맞음 - 정정·삭제·처리정지를 요구할 수 있다.
③	맞음 - 법이 정한 조건과 대상 범위에서 개인정보 전송을 요구할 수 있다.
④	맞음 - 완전자동 결정에 대해 거부 또는 설명을 요구할 수 있는 제도가 있다.
⑤	오답(정답 선지) - 가명정보에는 법 제28조의7의 특례로 관련 권리 규정이 적용되지 않는다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.20, p.47~50

가명정보 특례는 ‘아무 권리도 없다’는 뜻이 아니다. 처리자는 안전조치·재식별 금지·추가정보 분리 의무를 계속 부담하지만, 정보주체별 권리행사는 제한된다.

시험장 한 줄 암기

가명정보는 재식별을 막기 위해 개인별 열람·정정·삭제·처리정지 적용이 배제된다.

사진 출처: KakaoTalk_20260816_193019717_05.jpg

Q15. 다음 중 「개인정보 보호법」 상 ‘민감정보’ 처리에 관한 설명으로 가장 부적절한 것은

정답 결론

제공 정답: ③ | 검증 결론: ③

사진 원문 · 지문과 선지

다음 중 「개인정보 보호법」 상 ‘민감정보’ 처리에 관한 설명으로 가장 부적절한 것은?

- ① 감염병 대응 등 보건의 목적에 관한 개별 법률에 근거한 경우, 정보주체 동의 없이도 민감정보 처리가 가능할 수 있다.
- ② 통계작성·과학적 연구 등을 위한 ‘가명정보’로의 적정 조치 후 처리라면, 민감정보도 동의 없이 가능하나 재식별 금지와 결합 관리 의무가 수반된다.
- ③ 온라인 본인확인 서비스 제공을 목적으로 생체인식정보를 필수로 수집·저장하고, 일반 개인정보 동의서에 통합 고지했다면 ‘정당한 이익’에 따라 별도의 동의 없이 처리 가능하다.
- ④ 민감정보의 제3자 제공은 원칙적으로 법률 근거가 없으면 정보주체의 별도 동의를 요하고, 제공 내역 기록·보관 의무가 적용된다.
- ⑤ 민감정보를 처리하는 시스템은 접근권한 최소화·암호화·접속기록 점검 등 일반 개인정보보다 강화된 안전조치를 내부관리계획에 반영해야 한다.

STEP BY STEP

- 1 생체인식정보는 개인을 인증·식별할 목적으로 처리하면 민감정보에 해당한다.
- 2 민감정보 처리는 다른 개인정보 동의와 구분되는 별도 동의 또는 명확한 법률 근거가 원칙이다.
- 3 일반 동의서에 섞어 고지하고 ‘정당한 이익’만 주장하는 것은 별도 동의 요건을 충족하지 못하므로 ③이 틀렸다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 감염병예방법 등 개별 법률이 처리를 요구·허용할 수 있다.
②	맞음 - 통계·과학연구 등을 위한 가명정보 특례가 적용될 수 있지만 재식별 금지와 안전조치가 필요하다.
③	오답(정답 선지) - 생체인식정보의 민감정보 처리를 일반 동의에 묶거나 정당한 이익만으로 정당화할 수 없다.
④	맞음 - 제3자 제공에도 별도 근거와 고지·동의, 기록관리가 문제된다.
⑤	맞음 - 민감정보 시스템은 접근통제·암호화·로그 등 강화된 통제가 필요하다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.8, p.45~48, p.61~63

‘생체정보’ 전부가 자동으로 민감정보인 것은 아니고, 개인을 인증·식별할 목적으로 기술적으로 처리되는 생체인식정보가 핵심이다.

시험장 한 줄 암기

민감정보 = 별도 동의 또는 법률 근거. 일반 동의에 섞으면 안 된다.

사진 출처: KakaoTalk_20260816_193019717_06.jpg

Q16. 「개인정보 보호법」 제16조(개인정보의 수집 제한)의 ‘필요 최소한의 수집’ 원칙을 가...

정답 결론

제공 정답: ② | 검증 결론: ②

사진 원문 · 지문과 선지

「개인정보 보호법」 제16조(개인정보의 수집 제한)의 ‘필요 최소한의 수집’ 원칙을 가장 명백히 위반한 사례를 고르시오.

- ① (목적: 출입국 서식 작성 및 항공 보안) 국제선 항공권 예매 과정에서 성명·생년월일·연락처·여권번호를 필수로 수집
- ② (목적: 미성년자 유해물 구매 차단 및 본인 확인) 전자책(e-Book)만 구매하는 고객에게 주민등록번호와 신분증 이미지 제출을 필수로 요구
- ③ (목적: 결제 승인 및 취소·환불 처리) 병원 원무창구에서 카드 결제를 위해 카드 식별정보·승인번호를 수집
- ④ (목적: 배송지 자동 입력 편의) 택배 앱이 주소 자동완성을 위해 단말기 GPS 위치정보를 선택(동의 거부 시 주소 수기 입력 가능) 항목으로 제공
- ⑤ (목적: 투숙객 신원 확인 및 법정 신고) 호텔이 외국인 투숙객에 한해 여권번호를 필수로 수집하되, 내국인에 대해서는 주민등록번호를 수집하지 않음

STEP BY STEP

- 1 수집 목적을 먼저 확정한다.
- 2 그 목적 달성에 반드시 필요한 항목인지, 덜 침해적인 대체수단이 있는지 본다.
- 3 전자책 구매자의 연령·본인 확인은 휴대전화 인증 등 대체수단이 있는데 주민등록번호와 신분증 이미지까지 필수 요구하므로 과도하다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 국제선 운송과 출입국·보안 업무에 필요한 법정 정보일 수 있다.
②	오답(정답 선지) - 목적에 비해 고유식별정보와 신분증 사본을 과도하게 요구한다.
③	맞음 - 결제 승인·정산을 위한 최소 정보 범위로 볼 수 있다.
④	맞음 - 편의 기능을 선택항목으로 두고 수기 입력 대안을 제공했다.
⑤	맞음 - 외국인 투숙객의 법정 신고 목적에 맞춰 대상을 구분했다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.17~19, p.62

최소수집 판단은 ‘목적 적합성 → 필수성 → 대체수단 → 선택권’의 순서로 한다. 최소한의 개인정보라는 입증책임은 개인정보처리자에게 있다.

시험장 한 줄 암기

목적을 달성할 더 덜 침해적인 방법이 있으면 필수수집으로 만들 수 없다.

사진 출처: KakaoTalk_20260816_193019717_07.jpg

Q21. 다음 중 「개인정보 보호법」 제31조에 따라 개인정보 보호책임자(CPO)가 반드시 수행...

정답 결론

제공 정답: ⑤ | 검증 결론: ⑤

사진 원문 · 지문과 선지

다음 중 「개인정보 보호법」 제31조에 따라 개인정보 보호책임자(CPO)가 반드시 수행해야 할 의무가 아닌 것은?

- ① 개인정보 보호 계획의 수립 및 시행
- ② 개인정보 처리 실태 및 관행의 정기적인 조사 및 개선
- ③ 개인정보 처리와 관련한 불만의 처리 및 피해 구제
- ④ 개인정보 유출 사실 및 대응조치 보고
- ⑤ 개인정보 전담 조직의 신설, 인력, 예산 규모에 대한 결정 및 승인

STEP BY STEP

- 1 CPO는 보호계획 수립·시행, 실태조사·개선, 불만처리·피해구제, 유출·오남용 방지 통제, 교육과 파일 관리·감독을 담당한다.
- 2 조직·인력·예산의 필요성을 제안하고 조정할 수는 있다.
- 3 그러나 회사 차원의 전담조직 신설과 인력·예산을 최종 결정·승인하는 권한은 대표자나 경영진의 책임이므로 ⑤는 법정 필수업무가 아니다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - CPO의 핵심 법정업무다.
②	맞음 - 처리 실태와 관행을 조사하고 개선해야 한다.
③	맞음 - 정보주체 불만과 피해구제 업무를 담당한다.
④	맞음 - 유출 대응 체계와 보고·통제를 관리하는 역할에 포함된다.
⑤	오답(정답 선지) - 제안·조정만 가능하지만 최종 조직·예산 승인까지 CPO의 법정 의무로 보기는 어렵다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.25~27

CPO는 독립성과 접근권한을 보장받아야 하지만, 경영진의 책임을 대신하는 사람은 아니다. 대표자는 인적·물적 자원을 제공하고 CPO가 업무를 수행할 수 있도록 지원해야 한다.

시험장 한 줄 암기

CPO는 보호업무를 총괄하지만 회사 예산·조직의 최종 승인권자는 아니다.

사진 출처: KakaoTalk_20260816_193019717_08.jpg

Q22. 개인정보처리자가 공개해야 하는 ‘개인정보 처리방침’ 필수 항목을 점검하려 한다. 다음 ...

정답 결론

제공 정답: ④ | 검증 결론: ④

사진 원문 · 지문과 선지

개인정보처리자가 공개해야 하는 ‘개인정보 처리방침’ 필수 항목을 점검하려 한다. 다음 중 반드시 포함해야 하는 항목을 고르시오.

- A. 개인정보의 처리 목적
- B. 정보주체의 열람·정정·삭제·처리정지 등 권리 행사 절차 및 방법
- C. 개인정보 보호책임자의 성명 또는 개인정보 업무 담당부서 및 고충사항을 처리하는 부서에 관한 사항
- D. 개인정보 파기에 관한 사항
- E. 내부관리계획에 따라 수행하는 기술적·관리적·물리적 보호조치에 관한 사항

- ① A, B
- ② A, C
- ③ A, B, C
- ④ A, B, C, D
- ⑤ A, B, C, D, E

STEP BY STEP

- 1 처리방침은 외부 공개 문서이므로 처리 목적, 보유기간, 제3자 제공·위탁, 권리행사, 파기, CPO 등 정보주체가 알아야 할 사항을 담는다.
- 2 A·B·C·D는 법령상 필수 공개 항목에 해당한다.
- 3 E처럼 내부관리계획의 구체적 기술·관리·물리 조치 전체를 공개하는 것은 필수항목이 아니고, 안전성 확보조치에 관한 개괄적 사항과 내부 보안 세부정보는 구분해야 한다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	오답 - C와 D가 빠졌다.
②	오답 - B와 D가 빠졌다.
③	오답 - D가 빠졌다.
④	정답 - A·B·C·D가 모두 필수 공개항목이다.
⑤	오답 - E의 내부관리계획 세부 보호조치까지 처리방침에 반드시 공개할 의무는 없다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.37, p.50, p.74

처리방침은 정보주체 관점의 투명성 문서이고, 내부관리계획은 조직 내부의 안전조치 운영문서다. 두 문서를 섞으면 안 된다.

시험장 한 줄 암기

처리방침은 외부 공개, 내부관리계획은 내부 통제.

사진 출처: KakaoTalk_20260816_193019717_09.jpg

Q23. B은행은 고객 C씨가 대출 사기를 당했다는 이유로 수사기관의 ‘전화 한 통’만으로 C씨…

정답 결론

제공 정답: ② | 검증 결론: ②

사진 원문 · 지문과 선지

B은행은 고객 C씨가 대출 사기를 당했다는 이유로 수사기관의 ‘전화 한 통’만으로 C씨의 거래내역을 제공했다. 「개인 정보 보호법」 제18조에 따른 제3자 제공 요건 충족 여부로 가장 적절한 판단은?

- ① 요건 충족, 적법 제공
- ② 서면 요청 미비로 부적법 제공
- ③ 수사 목적이므로 구두 요청만으로도 적법
- ④ 긴급한 피해 방지 사유에 해당해 적법
- ⑤ 금융법 특례로 법 적용 제외

STEP BY STEP

- 1 수사 목적이라는 이유만으로 개인정보 제공이 자동 허용되는 것은 아니다.
- 2 법률상 요청권한, 요청기관, 대상·범위·목적, 문서 등 적법한 절차를 확인해야 한다.
- 3 단순 전화 요청만으로 거래내역을 넘겼다면 근거와 절차 확인이 부족하므로 부적법 판단이 가장 타당하다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	오답 - 전화만으로 법적 근거와 요청 범위를 확인하기 어렵다.
②	정답 - 적법한 문서 요청과 권한·범위 확인 없이 제공했다.
③	오답 - 수사 목적도 법률이 정한 요건과 절차를 따라야 한다.
④	오답 - 지문만으로 생명·신체·재산의 급박한 이익을 위한 긴급 제공 요건이 입증되지 않는다.
⑤	오답 - 금융정보에는 특별법이 적용될 수 있지만 개인정보 보호원칙이 전면 배제되는 것은 아니다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.21~24, p.63~66

기관 요청을 받으면 ‘요청기관 권한 → 법적 근거 → 대상자·항목 → 이용목적 → 보유기간 → 문서·기록’ 순으로 확인한다. 최소범위만 제공하고 제공기록을 남긴다.

시험장 한 줄 암기
수사기관이라는 이름보다 법적 근거와 적절한 요청 절차가 먼저다.

사진 출처: KakaoTalk_20260816_193019717_10.jpg

Q28. 배달 플랫폼 E사는 라이더의 실시간 위치 정보를 광고주에게 제공해 서비스 품질 분석에 ...

정답 결론

제공 정답: ③ | 검증 결론: ③

사진 원문 · 지문과 선지

배달 플랫폼 E사는 라이더의 실시간 위치 정보를 광고주에게 제공해 서비스 품질 분석에 활용하려 한다. 「개인정보 보호법」 제18조에 따른 목적 외 제3자 제공 요건을 충족하려면 가장 먼저 수행해야 할 조치는?

- ① 광고주와 위치정보 공동관리 계약 체결
- ② 국외 이전 신고
- ③ 정보주체(라이더)로부터 별도 동의를 받기
- ④ 보유기간을 3년으로 단축
- ⑤ 위치정보를 가명처리 후 제공

STEP BY STEP

- 1 라이더 위치정보의 원래 수집 목적과 광고주의 품질분석 목적이 같은지 확인한다.
- 2 원래 목적 범위를 벗어난 제3자 제공이면 법 제18조의 별도 근거가 필요하다.
- 3 광고분석은 일반적으로 법정 예외가 아니므로 제공받는 자·목적·항목·보유기간 등을 알리고 별도 동의를 먼저 받아야 한다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	오답 - 계약만으로 정보주체에 대한 적법 근거가 생기지 않는다.
②	오답 - 국내 광고주 제공이라면 국외이전 문제가 아니며, 일반적인 ‘국외이전 신고’가 선행요건도 아니다.
③	정답 - 목적 외 제3자 제공에 대한 별도 동의가 우선이다.
④	오답 - 보유기간 단축만으로 제공의 적법성이 확보되지 않는다.
⑤	오답 - 가명처리는 위험을 낮추지만 광고 제공의 법적 근거를 자동으로 대체하지 않는다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.18, p.21~24, p.34, p.63~66

위치정보는 개인정보 보호법뿐 아니라 위치정보법 적용도 함께 검토한다. 실시간 개인위치정보를 제3자에게 제공하면 별도 동의와 제공사실 통보 의무가 추가될 수 있다.

시험장 한 줄 암기

목적 외 제3자 제공은 계약이나 가명처리보다 먼저 적법 근거를 확보한다.

사진 출처: KakaoTalk_20260816_193019717_11.jpg

Q30. 다음 중 단체소송에 대한 설명으로 가장 적절하지 않은 것을 고르시오.

정답 결론

제공 정답: ④ | 검증 결론: ④

사진 원문 · 지문과 선지

다음 중 단체소송에 대한 설명으로 가장 적절하지 않은 것을 고르시오.

- ① 개인정보처리자가 집단분쟁조정을 거부하거나 그 결과를 수락하지 않을 경우 전체 피해자들의 이익을 위해 권리침해 행위의 금지 및 중지를 요구하는 소송이다.
- ② 단체소송은 위법행위의 금지 및 중지가 목적이다.
- ③ 단체소송의 원고는 변호사를 소송대리인으로 선임하여야 한다.
- ④ 다수의 피해자가 공동으로 제기하는 소송이다.
- ⑤ 외국사업자에 적용하는 경우 대한민국에 있는 이들의 주된 사무소·영업소 또는 업무담당자의 주소에 따라 정한다.

STEP BY STEP

- 1 개인정보 단체소송은 손해배상액을 나누어 받는 집단소송과 구조가 다르다.
- 2 일정한 소비자단체·비영리민간단체가 권리침해 행위의 금지·중지를 청구한다.
- 3 따라서 피해자 다수가 직접 공동원고가 된다는 ④는 집단소송에 가까운 설명으로 틀렸다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 집단분쟁조정이 거부되거나 수락되지 않을 경우 등 법정 요건 아래 금지·중지를 청구한다.
②	맞음 - 단체소송의 직접 목적은 위법행위의 금지·중지다.
③	맞음 - 법이 정한 소송수행 요건을 따라 변호사를 대리인으로 선임한다.
④	오답(정답 선지) - 다수 피해자가 직접 공동제기하는 소송이 아니라 적격단체가 제기한다.
⑤	맞음 - 외국사업자 관련 관할 특례를 설명한다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.90~92

집단분쟁조정은 조정절차, 단체소송은 금지·중지 청구, 손해배상은 개별 또는 별도 절차라는 차이를 표로 외우면 혼동이 줄어든다.

시험장 한 줄 암기
단체소송의 원고는 ‘피해자 다수’가 아니라 법정 적격단체다.

사진 출처: KakaoTalk_20260816_193019717_12.jpg

3과목

개인정보 라이프사이클 관리

수집 · 동의 · 국외이전 · 파기

오답 13/25문항 · 정답률 48.0%

수록 문항: Q32, Q35, Q36, Q40, Q41, Q45, Q46, Q48, Q49, Q50, Q51, Q52, Q53

이 과목은 문장 속 ‘원칙·예외·기준일·주체’를 먼저 표시한 뒤 선지를 판정하세요.

Q32. A기관이 ‘가명정보’를 활용한 통계·연구 과제를 추진하면서 개인정보처리방침 개정을 준비...

정답 결론

제공 정답: ④ | 검증 결론: ④

사진 원문 · 지문과 선지

A기관이 ‘가명정보’를 활용한 통계·연구 과제를 추진하면서 개인정보처리방침 개정을 준비 중이다. 개인정보 처리방침에 포함할 사항으로 가장 적절하지 않은 것은?

- ① 가명정보 처리 목적과 법적 근거(통계작성·과학적 연구·공익적 기록보존 등)
- ② 가명정보의 처리 범위(처리 항목의 유형, 대략적 보존기간, 제공·위탁 여부의 요지)
- ③ 가명정보 처리 시 적용하는 안전조치의 개요(추가정보 분리, 권한·접근기록 관리 등)
- ④ 가명정보 결합키에 대한 정보(해시값, 내부 식별자 매핑 테이블의 표본 스냅샷 등)
- ⑤ 가명정보 관련 문의·권리행사 접점(담당 부서, 국내대리인 등 연락처)

STEP BY STEP

- 1 처리방침은 가명정보의 목적, 항목, 보유기간, 제공·위탁, 안전조치의 개요 등 투명성 정보를 제공한다.
- 2 그러나 결합키·매핑테이블은 가명정보를 특정 개인과 연결할 수 있는 핵심 추가정보다.
- 3 이 값을 외부 처리방침에 구체적으로 공개하면 재식별과 보안위험이 커지므로 ④가 부적절하다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 통계·과학연구·공익적 기록보존 등 처리 목적과 근거는 공개 필요성이 크다.
②	맞음 - 항목 유형, 보유기간, 제공·위탁 여부의 요지는 투명성 확보에 도움이 된다.
③	맞음 - 추가정보 분리와 접근권한 등 안전조치의 개요를 설명할 수 있다.
④	오답(정답 선지) - 실제 결합키·해시값·매핑 샘플은 추가정보 노출과 재식별 위험을 만든다.
⑤	맞음 - 문의 창구와 연락처를 명확히 해야 한다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.47~50, p.53~54

외부에는 ‘무슨 통제를 하는지’를 설명하되 ‘어떻게 우회할 수 있는지’가 드러나는 비밀값·키·매핑정보는 공개하지 않는다. 추가정보는 가명정보와 분리 보관하고 접근권한을 최소화한다.

시험장 한 줄 암기
처리방침에는 통제의 개요, 결합키·매핑값은 비공개.

사진 출처: KakaoTalk_20260816_193019717_13.jpg

Q35. 개인정보 파기 원칙에 대한 설명으로 틀린 것은

정답 결론

제공 정답: ① | 검증 결론: ①

사진 원문 · 지문과 선지

개인정보 파기 원칙에 대한 설명으로 틀린 것은?

- ① 보유기간 경과 시 지체 없이 10일 이내에 파기한다.
- ② 파기 대상 데이터는 복구가 불가능한 방법으로 영구 삭제해야 한다.
- ③ 파기관리는 개인정보 보호책임자가 승인 후 문서화한다.
- ④ 다른 법령에 따라 반드시 보존해야 하는 경우에는 그 기간 동안 별도 보관 후, 보존기간이 모두 끝나면 지체 없이 파기한다.
- ⑤ 출력물 파기는 분쇄 또는 소각 등 물리적 방법을 사용한다.

STEP BY STEP

- 1 개인정보는 보유기간 경과나 처리목적 달성 등 불필요하게 된 때 지체 없이 파기해야 한다.
- 2 시행령상 정당한 사유가 없는 한 그 날부터 5일 이내 파기가 기준이다.
- 3 ①은 10일이라고 하여 기간을 잘못 제시했으므로 틀렸다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	오답(정답 선지) - 일반 기준은 10일이 아니라 정당한 사유가 없는 한 5일 이내다.
②	맞음 - 전자파일은 복원이 불가능한 방법으로 영구 삭제한다.
③	맞음 - 파기 승인·수행·확인 내역을 내부 절차에 따라 기록하는 것이 적절하다.
④	맞음 - 법정 보존정보는 다른 정보와 분리하여 필요한 기간만 보존한 뒤 파기한다.
⑤	맞음 - 종이는 분쇄·소각 등 복구가 어렵도록 물리적으로 파기한다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.28~29, p.76, p.79~80

‘5일’은 파기 실행의 일반적인 시행령 기준이고, ‘지체 없이’가 상위 원칙이다. 백업·캐시·로그에도 동일하게 삭제정책과 만료 절차를 마련해야 한다.

시험장 한 줄 암기

목적 달성·보유기간 경과 → 지체 없이, 특별한 사유 없으면 5일 이내 파기.

사진 출처: KakaoTalk_20260816_193019717_14.jpg

Q36. 개인정보처리자는 개인정보 수집·이용 시 정보주체에게 법령에서 정한 사항을 고지하여야 한...

정답 결론

제공 정답: ① | 검증 결론: ①

사진 원문 · 지문과 선지

개인정보처리자는 개인정보 수집·이용 시 정보주체에게 법령에서 정한 사항을 고지하여야 한다. 다음 중 반드시 고지해야 하는 항목으로 적절하지 않은 것을 고르시오.

- ① 개인정보 수집 법적 근거
- ② 수집하려는 개인정보의 항목
- ③ 개인정보 보유 및 이용 기간
- ④ 개인정보의 수집·이용 목적
- ⑤ 동의 거부 권리 및 거부에 따른 불이익이 있는 경우 그 불이익 내용

STEP BY STEP

- 1 동의를 받아 수집·이용할 때 법은 목적, 항목, 보유·이용기간, 거부권과 불이익을 알려야 한다.
- 2 ①의 '법적 근거'는 투명성을 위해 표시할 수 있지만 동의 획득 시의 네 가지 필수 고지항목 자체는 아니다.
- 3 따라서 반드시 고지할 항목으로 적절하지 않은 것은 ①이다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	오답(정답 선지) - 동의 기반 수집·이용의 법정 필수 고지 네 항목에는 '법적 근거'가 별도로 열거되지 않는다.
②	맞음 - 무엇을 수집하는지 알려야 한다.
③	맞음 - 언제까지 보유·이용하는지 알려야 한다.
④	맞음 - 왜 수집·이용하는지 알려야 한다.
⑤	맞음 - 거부권과 거부 시 불이익이 있으면 그 내용을 알려야 한다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.17~19, p.61~62

동의서 기본 4종 세트는 '목적·항목·기간·거부권/불이익'이다. 법정 근거로 동의 없이 처리하는 경우에는 근거와 처리 필요성을 별도로 문서화하는 것이 좋다.

시험장 한 줄 암기

동의 고지 4종 = 목적, 항목, 기간, 거부권 · 불이익.

사진 출처: KakaoTalk_20260816_193019717_15.jpg

Q40. 영리 목적의 광고성 정보 전송 제한에 대한 설명으로 적절하지 않은 것을 고르시오.

정답 결론

제공 정답: ⑤ | 검증 결론: ⑤

사진 원문 · 지문과 선지

영리 목적의 광고성 정보 전송 제한에 대한 설명으로 적절하지 않은 것을 고르시오.

- ① 누구든지 전자적 전송 매체를 이용하여 영리 목적의 광고성 정보를 전송하려면 그 수신자의 명시적인 사전 동의를 받아야 한다.
- ② 수신자가 수신 거부 또는 수신 동의를 철회하는 때에 전송에 이용된 수신자의 연락처 외의 정보를 전송자에게 제공하도록 요구하여 수신 거부 또는 수신 동의를 철회를 어렵게 해서는 안 된다.
- ③ 오후 9시부터 그다음 날 오전 8시까지의 시간에 전자적 전송 매체를 이용하여 영리 목적의 광고성 정보를 전송하려는 자는 수신자로부터 별도의 사전 동의를 받아야 한다.
- ④ 전자우편을 통한 광고성 정보 전송은 영리 목적의 광고성 정보에 대한 사전 동의를 받았다면 추가적인 별도 동의 없이 오후 9시부터 그 다음 날 오전 8시까지 전송이 가능하다.
- ⑤ 대가를 지불한 거래 관계를 통해 직접 연락처를 수집한 사업자가 거래 종료 후 6개월 이내에 자신이 처리하고 수신자와 거래한 것과 같은 종류의 재화 등에 대한 영리 목적의 광고성 정보를 전송하는 경우 명시적인 사전 동의를 받아야 한다.

STEP BY STEP

- 1 광고성 정보 전송은 명시적 사전동의를 원칙이다.
- 2 다만 거래관계에서 직접 연락처를 수집하고 거래 종료 후 6개월 이내 같은 종류의 재화·용역을 광고하는 경우에는 법정 예외가 적용될 수 있다.
- 3 ⑤는 이 예외상황에서도 반드시 사전동의를 받아야 한다고 했으므로 부적절하다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 사전동의 원칙을 설명한다.
②	맞음 - 거부·철회를 어렵게 하는 추가정보 요구는 금지된다.
③	맞음 - 야간 전송은 원칙적으로 별도 사전동의를 문제된다.
④	맞음 - 전자우편은 야간 별도동의 규정의 적용 방식이 문자·전화 등과 다르므로 일반 사전동의를 있으면 전송할 수 있다.
⑤	오답(정답 선지) - 직접 수집한 연락처로 거래 종료 후 6개월 내 같은 종류의 재화 등을 광고하는 법정 예외를 부정했다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.34~36

광고 문제는 '사전동의 원칙 → 기존 거래관계 6개월 예외 → 야간 별도동의 → 표시사항 → 2년마다 동의사실 확인' 순서로 정리한다.

시험장 한 줄 암기

기존 거래관계 + 직접 수집 + 6개월 + 같은 종류 = 사전동의 예외 가능.

사진 출처: KakaoTalk_20260816_193019717_16.jpg

Q41. 개인정보처리자는 다른 법령에 근거하여 개인정보를 보존해야 하는 경우에는 파기하지 않고 ...

검증 경고

제공 정답: ⑤ | 검증 결론: 정답 없음 - ⑤도 현행 기준상 맞음

검증 경고

문항·해설 오류. 전자상거래법 시행령은 소비자 불만 또는 분쟁처리 기록을 3년 보존하도록 하므로 ⑤는 틀린 선지가 아니다.

사진 원문 · 지문과 선지

개인정보처리자는 다른 법령에 근거하여 개인정보를 보존해야 하는 경우에는 파기하지 않고 보존할 수 있다. 개인정보 보존의무에 대한 설명으로 적절하지 않은 것을 고르시오.

- ① 통신사실 확인자료 : 12개월
- ② 컴퓨터 통신 또는 인터넷의 로그 기록자료, 정보통신기기 위치를 확인할 수 있는 접속지 추적자료 : 3개월
- ③ 표시/광고에 관한 기록 : 6개월
- ④ 계약 또는 청약철회에 관한 기록 : 5년
- ⑤ 소비자의 불만 또는 분쟁처리에 관한 기록 : 3년

STEP BY STEP

- 1 법정 보존기간은 어느 법령의 어떤 기록인지 구분해야 한다.
- 2 전자상거래법 시행령상 표시·광고는 6개월, 계약·청약철회와 대금결제·공급은 5년, 소비자 불만·분쟁처리는 3년이다.
- 3 따라서 ③·④·⑤는 모두 맞다. 나머지 통신자료 기간도 제시된 분류에 맞으므로 사진의 정답 ⑤는 방어하기 어렵다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 통신사실확인자료 중 법령이 정한 범주의 보존기간으로 제시된 값이다.
②	맞음 - 인터넷 로그·접속지 추적자료는 3개월 보존 범주가 있다.
③	맞음 - 표시·광고 기록은 6개월이다.
④	맞음 - 계약 또는 청약철회 기록은 5년이다.
⑤	맞음 - 소비자 불만 또는 분쟁처리 기록은 3년이다. 원문 해설의 '5년'이 잘못되었다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.28~29, p.80

전자상거래 6-5-5-3을 묶어 외운다: 표시광고 6개월, 계약·청약철회 5년, 결제·공급 5년, 불만·분쟁 3년. 법정 보존정보는 다른 개인정보와 분리 보관한다.

시험장 한 줄 암기

전자상거래 보존기간 = 6개월 / 5년 / 5년 / 3년.

사진 출처: KakaoTalk_20260816_193019717_17.jpg

Q45. 다음 중 제3자에 해당하는 보기로 묶인 것을 고르시오.

정답 결론

제공 정답: ⑤ | 검증 결론: ⑤

사진 원문 · 지문과 선지

다음 중 제3자에 해당하는 보기로 묶인 것을 고르시오.

- 가. 정보주체
- 나. 수탁자
- 다. 대리인
- 라. 영업양수자
- 마. 국외 이전(외국의 개인정보처리자)
- 바. 수집 목적 외 개인정보 제공받은 자
- ① 가, 라, 마
- ② 다, 바
- ③ 다, 라, 마
- ④ 나, 다, 라, 마, 바
- ⑤ 라, 마, 바

STEP BY STEP

1	제3자는 정보주체와 개인정보처리자 자신을 제외한 별도 주체를 말한다.
2	수탁자와 대리인은 처리자의 지휘·위임 범위에서 업무를 수행하므로 그 범위에서는 제3자 제공과 구별된다.
3	영업양수자, 독립된 외국 개인정보처리자, 목적 외로 정보를 제공받은 자는 제3자에 해당하므로 라·마·바가 맞다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	오답 - 정보주체인 가는 제3자가 아니다.
②	오답 - 대리인 다는 위임 범위에서 제3자로 보지 않는다.
③	오답 - 다가 포함되었다.
④	오답 - 수탁자 나와 대리인 다가 포함되었다.
⑤	정답 - 라·마·바는 독립된 수령자로서 제3자에 해당한다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.23~24, p.66~67

‘수탁자=무조건 제3자 아님’도 절대명제는 아니다. 수탁자가 위탁 목적을 벗어나 자기 목적에 이용하면 제3자 제공 문제와 책임이 발생할 수 있다.

시험장 한 줄 암기

지휘·위임 안의 수탁자·대리인은 제3자 제공과 구별, 독립 목적 수령자는 제3자.

사진 출처: KakaoTalk_20260816_193019717_18.jpg

Q46. 모바일 간편결제 서비스 K는 회원가입 과정에서 다음 4개 항목 ① 수집 목적 ② 수집 ...

정답 결론

제공 정답: ③ | 검증 결론: ③

사진 원문 · 지문과 선지

모바일 간편결제 서비스 K는 회원가입 과정에서 다음 4개 항목 ① 수집 목적 ② 수집 항목 ③ 보유·이용 기간 ④ 국외 이전 여부를 고지하였다. 「개인정보 보호법」 제17조 및 시행령 제15조(동의 획득 시 고지사항)에 따라 추가로 반드시 고지해야 할 필수 항목은?

- ① 개인정보 처리자의 상호·연락처
- ② 수탁자 현황
- ③ 동의를 거부할 권리 및 거부에 따른 불이익
- ④ 제3자 제공 현황
- ⑤ 파기 절차·방법

STEP BY STEP

- 1 동의를 받을 때에는 목적·항목·보유기간 외에 동의 거부권과 거부 시 불이익을 알려야 한다.
- 2 지문에는 목적·항목·기간은 있지만 거부권과 불이익 안내가 없다.
- 3 따라서 추가 필수항목은 ③이다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	오답 - 처리자 연락처는 처리방침 등에서 공개되지만 이 문항의 동의 고지 추가 핵심은 아니다.
②	오답 - 위탁 여부는 처리 형태에 따라 공개하나 모든 수집동의의 필수 추가항목은 아니다.
③	정답 - 동의 거부권 및 불이익이 있으면 그 내용을 반드시 알려야 한다.
④	오답 - 실제 제3자 제공 동의를 받는 경우에는 수령자·목적·항목·기간 등이 필요하지만 지문의 일반 수집동의의 필수 추가항목과 다르다.
⑤	오답 - 파기절차·방법은 처리방침 항목이지 수집동의의 필수 고지 네 항목은 아니다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.17~19, p.22

국외이전 동의를 별도로 받는다면 이전 항목, 국가, 시기·방법, 이전받는 자, 목적·보유기간, 거부방법·효과까지 별도 고지가 필요하다.

시험장 한 줄 암기
동의서는 거부권과 불이익 안내가 빠지기 쉽다.

사진 출처: KakaoTalk_20260816_193019717_19.jpg

Q48. 개인정보의 국외이전에 대한 설명으로 적절하지 않은 것을 고르시오.

검증 경고**제공 정답: ① | 검증 결론: 문항 오류 가능 - ① 외에 ③도 부정확****검증 경고**

복수 오답 위험. ①은 국외에서의 수집일 뿐 국내 처리자의 ‘이전’ 행위가 없다는 점에서 부적절하다. ③의 ISMS-P를 국외이전 인증으로 단정한 부분도 현행 법체계상 부정확하다.

사진 원문 · 지문과 선지

개인정보의 국외이전에 대한 설명으로 적절하지 않은 것을 고르시오.

- ① 해외에서 한국인의 공개된 개인정보를 수집하는 경우 개인정보의 국외 이전에 해당한다.
- ② 개인정보를 국외로 제공(조회되는 경우 포함)·처리위탁·보관하는 것은 원칙적으로 금지되어 있다.
- ③ 해외기업이 개인정보 보호 인증(ISMS-P)을 취득한 경우, 법 제28조의8제1항제4호에 따라 국내기업에서 해당 해외기업으로 개인정보를 제공(조회되는 경우 포함)·처리위탁·보관할 때 개인정보의 국외 이전에 관한 정보주체의 별도 동의 획득이 불필요하다.
- ④ 보호위원회는 서류를 받은 날로부터 30일 이내에 그 처리 결과를 문서로 알려야 한다.
- ⑤ 개인정보 국외이전 관련 규정을 위반하거나 개인정보보호 수준이 취약하여 국외이전 시 정보주체의 피해가 예상되는 경우, 보호위원회에서는 개인정보 국외이전 중지를 명령할 수 있다.

STEP BY STEP

- 1 국외이전은 국외로 제공·조회·처리위탁·보관되는 이동 또는 접근 구조를 말한다.
- 2 해외 사업자가 해외에서 공개정보를 직접 수집했다면 국내 개인정보처리자가 국외로 ‘이전’한 행위가 없어 ①은 부적절하다.
- 3 또한 제28조의8제1항제4호는 보호위원회가 고시하는 국외이전 관련 개인정보 보호 인증과 후속조치를 요구한다. 일반 ISMS-P 취득만으로 자동 충족한다고 단정할 수 없어 ③도 문제다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	오답 - 해외에서 직접 수집한 것과 국내에서 국외로 이전한 것은 구별된다. 다만 국내법의 역외적용 여부는 별도 문제다.
②	맞음 - 국외 제공·조회·위탁·보관은 원칙 금지 후 법정 근거가 있을 때 허용되는 구조다.
③	오답 가능 - ISMS-P를 곧바로 제28조의8의 국외이전 인증으로 볼 수 없다. 지정 인증과 안전조치·권리보장 조치를 확인해야 한다.
④	맞음 - 중지명령 이의제기 처리 등 해당 절차에서 정한 통지기한을 설명한다.
⑤	맞음 - 위반 또는 현저한 피해 우려가 있으면 국외이전 중지명령이 가능하다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.22~23, p.40, p.66~70

국외이전 허용근거는 별도 동의, 법률·조약, 계약 이행에 필요한 위탁·보관과 공개/통지, 지정 인증, 동등성 인정 등으로 나누어 외운다.

시험장 한 줄 암기

해외에서 수집 ≠ 국내에서 국외로 이전. ISMS-P ≠ 자동 국외이전 면허.

사진 출처: KakaoTalk_20260816_193019717_20.jpg

Q49. 개인정보의 국외이전을 위해 정보주체에게 별도 동의를 받을 때 고지사항으로 적절하지 않은...

정답 결론

제공 정답: ① | 검증 결론: ①

사진 원문 · 지문과 선지

개인정보의 국외이전을 위해 정보주체에게 별도 동의를 받을 때 고지사항으로 적절하지 않은 것을 고르시오.

- ① 개인정보를 이전하는 자의 성명, 이전 목적
- ② 개인정보가 이전되는 국가, 시기 및 방법
- ③ 개인정보를 이전받는 자의 성명(법인인 경우에는 그 명칭과 연락처를 말한다)
- ④ 개인정보를 이전받는 자의 개인정보 이용 목적 및 보유·이용 기간
- ⑤ 개인정보의 이전을 거부하는 방법, 절차 및 거부의 효과

STEP BY STEP

- 1 국외이전 동의 시에는 이전되는 개인정보 항목, 국가, 시기·방법, 이전받는 자의 명칭·연락처, 이용 목적·보유기간, 거부 방법·절차·효과를 알려야 한다.
- 2 ①의 ‘이전하는 자의 성명, 이전 목적’은 법정 고지항목의 정확한 표현이 아니다.
- 3 따라서 ①이 부적절하다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	오답(정답 선지) - 이전하는 자의 성명·이전 목적은 조문에 열거된 국외이전 동의 고지항목이 아니다.
②	맞음 - 이전 국가와 시기·방법을 알려야 한다.
③	맞음 - 수령자 명칭과 연락처를 알려야 한다.
④	맞음 - 수령자의 이용 목적과 보유·이용기간을 알려야 한다.
⑤	맞음 - 거부방법·절차와 거부 효과를 알려야 한다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.22, p.67

‘이전되는 개인정보 항목’도 필수다. 시험에서는 이전하는 자와 이전받는 자를 바꾸거나, 이전 목적과 수령자의 이용 목적을 섞어 함정을 만든다.

시험장 한 줄 암기

국가·시기·방법 / 수령자·연락처 / 목적·기간 / 거부방법·효과 / 이전 항목.

사진 출처: KakaoTalk_20260816_193019717_21.jpg

Q50. 개인정보 수집 출처 및 이용·제공 내역 통지에 대한 설명으로 적절하지 않은 것을 고르시...

정답 결론

제공 정답: ② | 검증 결론: ②

사진 원문 · 지문과 선지

개인정보 수집 출처 및 이용·제공 내역 통지에 대한 설명으로 적절하지 않은 것을 고르시오.

- ① 개인정보처리자는 수집한 개인정보의 이용·제공 내역이나 해당 내역을 확인할 수 있는 방법을 정보주체에게 연 1회 이상 통지하여야 한다.
- ② 자체적으로 생산된 정보도 정보주체의 요구가 있으면 수집 출처 및 이용·제공 내역에 대해 알려야 한다.
- ③ 정당한 사유가 없는 한 정보주체의 요구가 있는 날로부터 3일 이내에 수집 출처, 처리 목적, 동의철회 권리를 알려야 한다.
- ④ 정보주체 이외로부터 수집한 개인정보는 개인정보의 수집 출처, 개인정보의 처리 목적, 개인정보 처리의 정지를 요구하거나 동의를 철회할 권리가 있다는 사실을 알려야 한다.
- ⑤ 연락처 등 정보주체에게 알릴 수 있는 개인정보가 없을 경우 통지 대상에서 제외된다.

STEP BY STEP

- 1 수집 출처 통지제도는 정보주체 이외의 자로부터 개인정보를 수집한 경우를 전제로 한다.
- 2 개인정보처리자가 자체 생성한 정보는 '정보주체 이외의 자로부터 수집한 정보'가 아니다.
- 3 따라서 자체 생성정보까지 출처 통지 대상이라고 한 ②가 부적절하다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 법정 요건에 해당하는 개인정보처리자는 이용·제공내역을 주기적으로 통지한다.
②	오답(정답 선지) - 자체 생성정보는 제20조의 수집 출처 통지 대상이 아니다.
③	맞음 - 요구를 받으면 정당한 사유가 없는 한 정해진 기간 내 출처·목적·정지/철회 권리를 알려야 한다.
④	맞음 - 제3자로부터 수집한 경우의 핵심 통지항목이다.
⑤	맞음 - 연락수단이 없어 통지가 불가능한 경우 등 법정 예외가 있다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.20, p.37

‘수집 출처 통지’와 ‘이용·제공내역 통지’는 대상과 요건이 다른 제도다. 출처 통지는 제3자 수집의 투명성, 이용내역 통지는 일정 규모 처리자의 정기 투명성에 초점이 있다.

시험장 한 줄 암기
자체 생성정보에는 ‘수집 출처’가 없다.

사진 출처: KakaoTalk_20260816_193019717_22.jpg

Q51. 정보주체 이외로부터 수집한 개인정보 통지 의무 개인 정보처리자 요건으로 적절한 것을 고르...

정답 결론

제공 정답: ① | 검증 결론: ①

사진 원문 · 지문과 선지

정보주체 이외로부터 수집한 개인정보 통지 의무 개인정보처리자 요건으로 적절한 것을 고르시오.

- 가. 5만 명 이상 정보주체에 관한 민감정보 또는 고유식별정보를 처리하는 자
나. 100만 명 이상의 정보주체에 관한 개인정보를 처리하는 자
다. 주민등록번호를 처리하는 자
라. 공공시스템 운영기관
마. 50만 명 이상의 정보주체와 관련된 개인정보를 내부 또는 외부와 연계하는 경우

- ① 가, 나
② 가, 다
③ 나, 다, 마
④ 나, 다, 라, 마
⑤ 가, 나, 다, 마

STEP BY STEP

- | | |
|---|--|
| 1 | 법은 일정 규모 이상 개인정보를 제3자로부터 수집·처리하는 자에게 적극적 통지의무를 둔다. |
| 2 | 기준은 5만 명 이상 민감정보·고유식별정보 처리 또는 100만 명 이상 개인정보 처리다. |
| 3 | 주민등록번호 처리 여부, 공공시스템 여부, 50만 명 연계 여부만으로 이 통지의무 기준이 되지는 않는다. |

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	정답 - 가와 나가 법정 규모 기준이다.
②	오답 - 다는 독립 기준이 아니다.
③	오답 - 다와 마가 포함되었다.
④	오답 - 다·라·마는 이 통지의무의 규모 기준이 아니다.
⑤	오답 - 다와 마가 추가되었다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.20, p.45~46

5만 기준은 모든 개인정보가 아니라 민감정보 또는 고유식별정보 처리라는 조건과 함께 외운다. 100만 기준은 일반 개인정보 전체 규모다.

시험장 한 줄 암기

출처 통지 규모 = 민감·고유 5만 또는 전체 100만.

사진 출처: KakaoTalk_20260816_193019717_23.jpg

Q52. 개인정보처리자는 정보주체로부터 적법하게 동의받기 위해서는 동의 조건을 모두 충족하여야 ...

정답 결론

제공 정답: ③ | 검증 결론: ③

사진 원문 · 지문과 선지

개인정보처리자는 정보주체로부터 적법하게 동의받기 위해서는 동의 조건을 모두 충족하여야 한다. 이에 대한 설명으로 적절하지 않은 것을 고르시오.

- ① 정보주체가 자유로운 의사에 따라 동의 여부를 결정할 수 있어야 한다.
- ② 동의 받으려는 내용이 구체적이고 명확해야 한다.
- ③ 동의서의 중요한 내용은 최소 9포인트 크기로, 다른 내용보다 20% 이상 크게 작성해야 한다.
- ④ 동의 받으려는 내용이 쉽게 읽고 이해할 수 있는 문구를 사용해야 한다.
- ⑤ 동의 여부를 명확하게 표시할 수 있는 방법을 정보주체에게 제공해야 한다.

STEP BY STEP

- 1 적법한 동의는 자유성, 구체성·명확성, 이해가능성, 명시적 의사표시가 핵심이다.
- 2 현행 지침은 중요한 내용을 시각적으로 구분하고 쉽게 이해하도록 요구하지만 9포인트·20%라는 획일적 수치 규칙을 일반 법정요건으로 두지 않는다.
- 3 따라서 ③이 부적절하다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 서비스 제공을 부당하게 묶어 강요하면 자유로운 동의가 아니다.
②	맞음 - 포괄적·추상적 표현만으로는 충분하지 않다.
③	오답(정답 선지) - 현행 기준에 없는 정량적 글자크기 규칙을 제시했다.
④	맞음 - 정보주체가 쉽게 읽고 이해할 수 있어야 한다.
⑤	맞음 - 체크·서명 등 동의 의사를 명확히 표시할 수 있어야 한다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.18~19, p.61~62

필수와 선택 동의를 분리하고, 선택동의 거부를 이유로 본질적 서비스를 거절하지 않도록 설계한다. 사전 체크된 동의란은 명시적 동의로 보기 어렵다.

시험장 한 줄 암기
동의를 숫자보다 자유·구체·명확·이해·명시.

사진 출처: KakaoTalk_20260816_193019717_24.jpg

Q53. 개인정보처리자는 정보주체의 서면 동의를 통해 개인정보를 수집하려는 경우는 대통령령으로 ...

정답 결론

제공 정답: ② | 검증 결론: ②

사진 원문 · 지문과 선지

개인정보처리자는 정보주체의 서면 동의를 통해 개인정보를 수집하려는 경우는 대통령령으로 정하는 중요한 내용을 보호위원회가 고시로 정하는 방법에 따라 명확히 표시하여 알아보기 쉽게 하여야 한다. 다음의 보기 중 명확히 표시해야 하는 항목으로 적절하지 않은 것을 고르시오.

- ① 재화나 서비스의 홍보 또는 판매 권유 등을 위하여 해당 개인정보를 이용하여 정보주체에게 연락할 수 있다는 사실
- ② 개인정보처리 위수탁에 관한 사항
- ③ 여권번호, 운전면허번호 및 외국인등록번호
- ④ 개인정보의 보유 및 이용 기간
- ⑤ 개인정보를 제공하는 자 및 개인정보를 제공받는 자의 개인정보 이용 목적

STEP BY STEP

- 1 서면 동의의 중요한 내용은 정보주체의 결정에 큰 영향을 주는 사항을 눈에 띄게 표시하는 제도다.
- 2 홍보 연락, 고유식별정보, 장기 보유기간, 제3자 제공받는 자와 목적 등은 중요한 표시 대상이 된다.
- 3 개인정보 처리위탁에 관한 사항 자체는 이 문항의 ‘명확히 표시할 중요내용’에 포함되지 않으므로 ②가 답이다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 마케팅 연락 가능성은 중요 표시 대상이다.
②	오답(정답 선지) - 위탁사항은 처리방침 공개 등 별도 규율을 받지만 여기의 중요 표시 대상에는 해당하지 않는다.
③	맞음 - 여권·운전면허·외국인등록번호는 고유식별정보로 중요한 표시 대상이다.
④	맞음 - 특히 장기 보유·이용은 의사결정에 중요한 정보다.
⑤	맞음 - 제3자 제공받는 자와 이용 목적은 중요한 표시 대상이다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.19, p.23, p.37

위탁은 개인정보처리자의 목적을 위해 수탁자가 처리하는 구조이고, 제3자 제공은 수령자의 목적을 위해 넘어가는 구조다. 두 개념을 구별하면 ②와 ⑤가 쉽게 나뉜다.

시험장 한 줄 암기

중요 표시: 마케팅, 민감·고유, 장기 보유, 제3자 제공. 위탁 자체는 별도 공개.

사진 출처: KakaoTalk_20260816_193019717_25.jpg

4과목

개인정보 보호조치

접근통제 · 로그 · 암호화

오답 10/30문항 · 정답률 66.7%

수록 문항: Q57, Q59, Q61, Q62, Q66, Q67, Q69, Q73, Q78, Q84

이 과목은 문장 속 ‘원칙·예외·기준일·주체’를 먼저 표시한 뒤 선지를 판정하세요.

Q57. 개인정보의 안전성 확보조치에 따른 ‘접속기록의 보관·점검’에 대한 설명으로 적절한 것을...

검증 경고

제공 정답: ① | 검증 결론: ①(2026.8.16 시행 기준)

검증 경고

시점형 문항. 2026년 7월 1일 시행된 고시 제2026-9호는 월 1회라는 고정주기 대신 내부관리계획에 점검 주기·방법·사후조치를 정하도록 규정한다.

사진 원문 · 지문과 선지

개인정보의 안전성 확보조치에 따른 ‘접속기록의 보관·점검’에 대한 설명으로 적절한 것을 모두 고른 것은?

- A. 5만 명 이상 정보주체의 개인정보를 처리하면 접속기록을 2년 이상 보관해야 한다.
- B. 접속기록 백업 시 덮어쓰기 방지(WORM) 매체 사용이 권고된다.
- C. 접속기록은 월 1회 이상 점검해야 하며 다운로드가 확인되면 사유를 확인해야 한다.
- D. 접속기록은 같은 서버 디렉터리에만 보관해도 무결성이 확보된다.

- ① A, B
- ② A, C
- ③ A, B, C
- ④ B, C, D
- ⑤ A, C, D

STEP BY STEP

- 1 접속기록은 원칙적으로 1년 이상 보관하되, 5만 명 이상 개인정보 시스템 등 고위험 범주는 2년 이상 보관한다.
- 2 위·변조 방지를 위해 별도 저장소, 접근통제, 무결성 검증, WORM 등 덮어쓰기 방지 수단을 사용할 수 있다.
- 3 현행 제8조제2항은 월 1회라는 숫자를 두지 않고 점검 주기·방법·사후조치를 내부관리계획에 정해 이행하도록 한다. 따라서 C는 현행 기준에서는 틀리다.
- 4 같은 서버의 같은 디렉터리만으로는 관리자 오용·장애·랜섬웨어로부터 무결성이 보장되지 않으므로 D도 틀려 A와 B만 남는다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	정답 - A와 B가 적절하다.
②	오답 - C의 월 1회 고정주기는 현행 규정과 맞지 않는다.
③	오답 - C가 포함되었다.
④	오답 - C와 D가 포함되었다.
⑤	오답 - C와 D가 포함되었다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.27, p.73~74, p.79~80

점검주기 자율화는 점검을 하지 않아도 된다는 뜻이 아니다. 처리 규모·민감도·다운로드 위험을 반영해 주기를 문서화 하고, 이상행위 탐지와 사후조치를 증적화해야 한다.

시험장 한 줄 암기

2026.7.1 이후: 월 1회 고정값 대신 내부관리계획에 주기·방법·사후조치.

사진 출처: KakaoTalk_20260816_193019717_26.jpg

Q59. 접근권한 관리에 관한 다음 설명 중 가장 적절하지 않은 것은

검증 경고

제공 정답: 사진 포함 문항 - 사용자 목록 누락 | 검증 결론: ③

검증 경고

첨부 사진에는 있으나 입력 목록에서 빠진 문항이다. 4과목 오답 10개라는 합계와도 일치하므로 포함했다.

사진 원문 · 지문과 선지

접근권한 관리에 관한 다음 설명 중 가장 적절하지 않은 것은?

- ① 업무상 필요한 최소 권한 부여와 직무분리를 원칙으로 설계한다.
- ② 신규 입사·부서이동·퇴직 등 신분변동 시 권한 부여·변경·말소 절차를 즉시 수행한다.
- ③ 공용계정은 감사추적성을 위해 사용해야 하며, 비밀번호 공유는 팀 효율성 향상을 위해 허용된다.
- ④ 중요 시스템·고위험 작업에는 다중요소인증(MFA)과 승인·지정 절차를 적용할 수 있다.
- ⑤ 정기적으로 권한·계정 목록을 점검·승인하고, 불용 계정은 잠금·말소한다.

STEP BY STEP

- 1 접근권한은 개인별 식별 가능한 계정을 기반으로 최소권한·직무분리를 적용한다.
- 2 공용계정과 비밀번호 공유는 누가 어떤 작업을 했는지 추적할 수 없게 만든다.
- 3 따라서 감사추적성을 높이기 위해 공용계정을 써야 한다는 ③은 정반대의 설명이다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 최소권한과 직무분리는 권한관리의 기본이다.
②	맞음 - 인사변동을 권한에 지체 없이 반영해야 한다.
③	오답(정답 선지) - 공용계정·비밀번호 공유는 식별성과 책임추적성을 훼손한다.
④	맞음 - 중요 작업에는 MFA와 승인 절차를 강화할 수 있다.
⑤	맞음 - 정기 재검토와 휴면·불용 계정 정리가 필요하다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.27, p.71~74

부득이한 시스템 공용계정이 있다면 사용자를 별도 승인하고, 접속 전 개인인증·세션기록·명령감사를 결합해 책임추적성을 보완해야 한다.

시험장 한 줄 암기

감사추적성은 공용계정이 아니라 개인별 계정에서 나온다.

사진 출처: KakaoTalk_20260816_193019717_27.jpg

Q61. 「개인정보의 안전성 확보조치 기준 고시」에 따른 ‘내부관리계획’ 필수 항목으로 옳지 않...

정답 결론

제공 정답: ⑤ | 검증 결론: ⑤

사진 원문 · 지문과 선지

「개인정보의 안전성 확보조치 기준 고시」에 따른 ‘내부관리계획’ 필수 항목으로 옳지 않은 것은?

- ① 개인정보보호 조직 및 책임
- ② 물리적 시설보호 절차
- ③ 개인정보 파기 절차
- ④ 정보주체 권리 보장 절차
- ⑤ 정보보호 산정 예산 편성 기준

STEP BY STEP

- 1 내부관리계획은 조직·책임, 접근권한, 접근통제, 암호화, 접속기록, 악성프로그램, 물리적 조치, 유출 대응, 위탁관리 등 보호조치를 문서화한다.
- 2 파기와 정보주체 권리처리 절차도 개인정보 관리체계상 내부 절차로 마련할 필요가 있다.
- 3 하지만 정보보호 예산을 어떤 산식으로 편성할지까지 법정 필수 항목으로 정한 것은 아니므로 ⑤가 답이다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 보호조직과 역할·책임을 정한다.
②	맞음 - 전산실·자료보관실 등 물리적 보호절차를 포함한다.
③	맞음 - 보유기간 종료 시 안전한 파기절차를 정한다.
④	맞음 - 권리요청 접수·확인·처리 절차를 마련한다.
⑤	오답(정답 선지) - 예산 확보는 중요하지만 특정 산정·편성 기준이 고시상 필수항목은 아니다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.25, p.27, p.73~74

내부관리계획은 문서만 만드는 것이 아니라 중요한 변경을 즉시 반영하고, CPO가 이행 실태를 연 1회 이상 점검·관리해야 한다.

시험장 한 줄 암기
내부관리계획은 보호조치 운영문서이지 예산 산식 규정이 아니다.

사진 출처: KakaoTalk_20260816_193019717_28.jpg

Q62. 다음 중 개인정보처리시스템 ‘접속기록’의 필수 기재 사항이 아닌 것은

정답 결론

제공 정답: ④ | 검증 결론: ④

사진 원문 · 지문과 선지

다음 중 개인정보처리시스템 ‘접속기록’의 필수 기재사항이 아닌 것은?

- ① 사용자 식별자(ID)
- ② 접속 일시
- ③ 접속 IP/호스트 정보
- ④ 접속 성공·실패 여부
- ⑤ 수행 업무

STEP BY STEP

- 1 접속기록은 누가, 언제, 어디에서, 누구의 정보에, 어떤 업무를 수행했는지 추적할 수 있어야 한다.
- 2 필수 요소는 사용자 식별자, 접속 일시, 접속지 정보, 처리한 정보주체 정보, 수행 업무 등이다.
- 3 성공·실패 여부는 유용한 보안로그 항목이지만 고시가 열거한 접속기록 필수항목은 아니므로 ④가 답이다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 작업자를 식별하는 ID가 필요하다.
②	맞음 - 사건의 시간축을 확인하는 접속 일시가 필요하다.
③	맞음 - IP 또는 호스트 등 접속지 정보가 필요하다.
④	오답(정답 선지) - 보안운영상 권장되지만 법정 접속기록 필수항목으로 열거되지는 않는다.
⑤	맞음 - 조회·수정·삭제·다운로드 등 수행업무를 남겨야 한다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.27, p.71, p.73, p.79~80

실무 로그에는 성공·실패, 세션ID, 대상 테이블, 건수, 다운로드 사유까지 추가하면 탐지력이 좋아진다. 법정 최소와 보안상 권장항목을 구분한다.

시험장 한 줄 암기

필수 추적 질문 = 누가 · 언제 · 어디서 · 누구 정보를 · 무엇을 했다.

사진 출처: KakaoTalk_20260816_193019717_29.jpg

Q66. 다음 중 「개인정보의 안전성 확보조치 기준」 제6조 (접근통제)에 따라 원격 접속 시 적...

정답 결론

제공 정답: ⑤ | 검증 결론: ⑤

사진 원문 · 지문과 선지

다음 중 「개인정보의 안전성 확보조치 기준」 제6조(접근통제)에 따라 원격 접속 시 적용해야 할 강화 인증 수단으로 가장 적절하지 않은 것은?

- ① OTP(One-Time Password)
- ② 보안 토큰(하드웨어 키)
- ③ 휴대전화 SMS 인증
- ④ 생체 인증(FIDO 지문)
- ⑤ 안전한 비밀번호(10자리 이상+3가지 조합)

STEP BY STEP

- 1 원격접속은 외부 네트워크에서 개인정보처리시스템에 접근하므로 계정탈취 위험이 높다.
- 2 강화 인증은 서로 다른 인증요소를 추가하거나 일회용·소유·생체요소를 사용해 단일 비밀번호의 한계를 보완한다.
- 3 복잡한 비밀번호도 여전히 단일 지식요소이므로 강화된 이중인증 수단이라고 할 수 없어 ⑤가 부적절하다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 일회용 비밀번호로 소유요소를 추가한다.
②	맞음 - 하드웨어 보안키는 강한 소유기반 인증이다.
③	맞음 - SMS는 취약점이 있으나 비밀번호와 결합하면 추가 인증요소로 기능한다.
④	맞음 - FIDO 생체인증은 단말 기반 강한 인증수단이 될 수 있다.
⑤	오답(정답 선지) - 길고 복잡해도 비밀번호 하나만 쓰면 단일요소 인증이다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.71~73

가능하면 피싱에 강한 FIDO2·보안키를 우선하고, SMS는 SIM 스와핑 위험 때문에 고위험 관리자 원격접속에서는 보조수단으로 본다.

시험장 한 줄 암기
복잡한 비밀번호 1개는 MFA가 아니다.

사진 출처: KakaoTalk_20260816_193027007.jpg

Q67. 다음 중 내부관리계획에 대한 설명으로 옳지 않은 것은 무엇인가

정답 결론

제공 정답: ② | 검증 결론: ②

사진 원문 · 지문과 선지

다음 중 내부관리계획에 대한 설명으로 옳지 않은 것은 무엇인가?

- ① 내부관리계획은 개인정보처리자의 고유 환경에 맞게 구체적으로 수립해야 한다.
- ② ‘내부관리계획’이라는 명칭을 반드시 사용해야 하며 다른 용어로 대체할 수 없다.
- ③ 내부관리계획은 전사적 계획 하에 시행되도록 사업주 또는 대표자의 승인을 받아야 한다.
- ④ 개인정보 보호책임자는 연 1회 이상 내부관리계획 이행 실태를 점검하여야 한다.
- ⑤ 내부관리계획에는 기술적·관리적·물리적 보호조치 등이 포함되어야 한다.

STEP BY STEP

- 1 내부관리계획의 본질은 조직 환경에 맞는 보호조치를 문서화하고 실제 시행하는 것이다.
- 2 문서 제목은 ‘개인정보보호 내부방침’, ‘보안관리규정’ 등 다른 명칭을 사용할 수 있다.
- 3 내용과 승인·시행·점검이 충족되면 되므로 특정 명칭만 강제한 ②가 틀렸다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 규모·업무·시스템·위험에 맞게 구체화해야 한다.
②	오답(정답 선지) - 명칭보다 법정 내용과 실제 이행이 중요하다.
③	맞음 - 경영진 승인과 전사적 시행이 필요하다.
④	맞음 - CPO는 이행 실태를 연 1회 이상 점검·관리한다.
⑤	맞음 - 기술·관리·물리 보호조치를 통합한다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.25, p.27, p.73~74

기존 정보보호 규정에 개인정보 안전조치 항목을 충분히 포함해 하나의 통합 규정으로 운영하는 것도 가능하다.

시험장 한 줄 암기

이름이 아니라 내용·승인·이행·점검이 핵심.

사진 출처: KakaoTalk_20260816_193027007_01.jpg

Q69. 개인정보 유·노출 방지 조치를 위한 예시로 적절하지 않은 것을 고르시오.

정답 결론

제공 정답: ③ | 검증 결론: ③

사진 원문 · 지문과 선지

개인정보 유·노출 방지 조치를 위한 예시로 적절하지 않은 것을 고르시오.

- ① 홈페이지 주소(URL), 소스코드, 임시 저장 페이지 등에 개인정보 사용 금지
- ② 시큐어 코딩(Secure coding) 도입
- ③ 개발 단계에서 충분한 테스트를 위해 실제 데이터(개인정보)를 활용
- ④ 로그인 시도 횟수 증가 시 캡차(CAPTCHA) 적용
- ⑤ 로그인 실패 비율에 대한 임계치 설정 모니터링

STEP BY STEP

- 1 개발·테스트 환경은 운영환경보다 통제가 약하고 접근자가 많아 유출 위험이 크다.
- 2 따라서 실제 개인정보 대신 합성데이터·마스킹·가명정보를 사용하고 운영데이터 반출을 제한해야 한다.
- 3 충분한 테스트를 이유로 실데이터를 쓰자는 ③은 부적절하다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - URL·소스·임시페이지에 개인정보가 남으면 검색·로그·캐시로 노출될 수 있다.
②	맞음 - 시큐어 코딩은 입력검증·인증·세션 취약점을 줄인다.
③	오답(정답 선지) - 실데이터 사용은 개발환경 유출 위험을 높인다.
④	맞음 - 반복 로그인 공격을 완화한다.
⑤	맞음 - 비정상 인증 패턴을 조기에 탐지할 수 있다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.74~76, p.84~85

실데이터가 불가피하면 최소표본, 가명·마스킹, 승인, 격리망, 다운로드 차단, 사용 후 즉시 파기와 로그 점검을 적용한다.

시험장 한 줄 암기

개발·테스트는 실데이터 대신 합성·가명·마스킹 데이터.

사진 출처: KakaoTalk_20260816_193027007_02.jpg

Q73. 개인정보 암호화 알고리즘 선택 기준에 따라 가장 부적절한 것은

정답 결론

제공 정답: ⑤ | 검증 결론: ⑤

사진 원문 · 지문과 선지

개인정보 암호화 알고리즘 선택 기준에 따라 가장 부적절한 것은?

- ① AES-256
- ② SEED-128
- ③ RSA-2048
- ④ SHA-256 해시 후 단방향 저장
- ⑤ DES

STEP BY STEP

- 1 암호화 알고리즘은 충분한 키 길이와 현재 알려진 공격에 대한 안전성을 가져야 한다.
- 2 AES-256·SEED-128은 대칭키, RSA-2048은 공개키, SHA-256은 비밀번호 등 복원이 필요 없는 값의 단방향 저장에 활용할 수 있다.
- 3 DES는 56비트 유효키로 전수공격에 취약해 더 이상 안전한 암호로 보지 않으므로 ⑤가 답이다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 충분한 키 길이의 대표적 대칭키 알고리즘이다.
②	맞음 - 국내 표준 대칭키 알고리즘으로 사용 가능하다.
③	맞음 - 공개키 암호에서 2048비트 이상이 일반 권고선이다.
④	맞음 - 비밀번호는 솔트와 반복·메모리강화 KDF를 함께 써야 하며, 단순 SHA-256만으로는 부족할 수 있다는 점을 보완해 이해해야 한다.
⑤	오답(정답 선지) - DES는 키 길이가 짧아 폐기된 알고리즘이다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.76~79

시험의 ④는 방향성상 맞지만 실무에서는 비밀번호를 SHA-256 한 번만 해시하지 않는다.
Argon2id·scrypt·PBKDF2·bcrypt 같은 솔트 기반 비밀번호 해시를 사용한다.

시험장 한 줄 암기

DES는 폐기. 비밀번호는 단순 해시가 아니라 솔트+느린 KDF.

사진 출처: KakaoTalk_20260816_193027007_03.jpg

Q78. 다음 중 SSL과 응용 프로그램 보안 처리 방법에 대한 설명으로 적절하지 않은 것은 무...

정답 결론

제공 정답: ④ | 검증 결론: ④

사진 원문 · 지문과 선지

다음 중 SSL과 응용 프로그램 보안 처리 방법에 대한 설명으로 적절하지 않은 것은 무엇인가?

- ① SSL은 클라이언트와 서버 간 전송되는 데이터 전체를 암호화하여 중간자 공격을 방지한다.
- ② HTTPS는 HTTP에 SSL을 적용한 프로토콜로, 주로 웹 브라우저와 웹 서버 간 통신 보안에 사용된다.
- ③ 응용 프로그램 보안은 이름, 주민등록번호, 카드번호 등 특정 데이터 항목만을 선별적으로 암호화할 수 있다.
- ④ SSL은 서버가 암호화를 요청하면, 클라이언트에 별도의 암호화 프로그램이 설치되어 데이터를 암호화한다.
- ⑤ 응용 프로그램 보안은 SSL과 달리 저장 중인 정보나 특정 항목에 대해 개별적으로 보안을 적용할 수 있다.

STEP BY STEP

- 1 TLS는 브라우저와 서버가 핸드셰이크로 암호군·키를 합의해 전송구간을 보호한다.
- 2 현대 브라우저와 운영체제에는 TLS 기능이 기본 내장되어 있어 일반적인 HTTPS 이용자가 별도 암호화 프로그램을 설치하지 않는다.
- 3 따라서 별도 프로그램 설치가 필요하다는 ④가 틀렸다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - TLS는 전송 중 기밀성·무결성·서버 인증을 제공해 MITM 위험을 낮춘다.
②	맞음 - 엄밀히는 현재 SSL 대신 TLS를 사용하지만 통상 HTTPS 설명으로 맞다.
③	맞음 - 애플리케이션 계층에서 특정 필드만 암호화할 수 있다.
④	오답(정답 선지) - 브라우저가 TLS를 기본 지원하므로 별도 클라이언트 프로그램 설치가 일반 요건이 아니다.
⑤	맞음 - 애플리케이션 암호화는 저장 데이터·특정 필드에 세밀하게 적용할 수 있다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.77~79, p.84~85

TLS는 전송 중 데이터만 보호한다. 서버에 도착해 복호화된 뒤와 데이터베이스 저장 상태는 별도 암호화·접근통제가 필요하다.

시험장 한 줄 암기

TLS = 전송구간, 애플리케이션 암호화 = 특정 필드·저장정보.

사진 출처: KakaoTalk_20260816_193027007_04.jpg

Q84. DRM(Digital Rights Management)과 DLP(Data Loss Pr...

정답 결론

제공 정답: ④ | 검증 결론: ④

사진 원문 · 지문과 선지

DRM(Digital Rights Management)과 DLP(Data Loss Prevention)에 대한 기술적 설명으로 적절하지 않은 것은?

- ① DRM은 문서·이미지·동영상 등 콘텐츠에 암호화, 워터마크, 권한제어(열람·편집·출력 제한 등)를 적용하여 불법 복제나 외부 유출을 방지하는 기술이다.
- ② DRM은 파일 자체에 보안 정책이 포함되어 있어, 파일이 외부로 반출되더라도 정책에 따라 열람이 제한되거나 추적이 가능하다.
- ③ DLP는 내부 사용자의 화면 캡처, 클립보드 사용, 프린터 출력 등을 탐지·차단하여 민감정보 유출을 예방하는 기술이다.
- ④ DLP는 네트워크 구간을 암호화하여 전송 중 데이터에 대한 무결성을 보장하고 중간자 공격(MITM)을 차단하는 기술이다.
- ⑤ DLP는 내부 시스템에서 개인정보·기밀정보 등의 패턴을 탐지하여 메일, 웹 업로드, 저장장치 복사 등 다양한 경로의 유출을 실시간으로 통제할 수 있다.

STEP BY STEP

- 1 DRM은 파일·콘텐츠 자체에 사용권한을 붙여 복제·열람·출력 등을 통제한다.
- 2 DLP는 개인정보 패턴과 반출 경로를 탐지해 메일·웹·USB·출력 등을 차단한다.
- 3 네트워크 암호화와 MITM 방지는 TLS·VPN의 기능이므로 이를 DLP라고 한 ④가 틀렸다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - DRM의 콘텐츠 권한통제 기능이다.
②	맞음 - 파일이 이동해도 정책이 따라가는 지속적 통제가 DRM의 특징이다.
③	맞음 - 엔드포인트 DLP는 캡처·클립보드·출력 등을 통제할 수 있다.
④	오답(정답 선지) - 전송구간 암호화와 MITM 방지는 TLS/VPN 영역이다.
⑤	맞음 - 네트워크·엔드포인트 DLP는 다양한 반출채널을 탐지·차단한다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.84~85

DRM은 '문서가 어디로 가도 권한 유지', DLP는 '민감정보가 밖으로 나가는 경로 차단', TLS/VPN은 '전송구간 보호'로 구분한다.

시험장 한 줄 암기

DRM=콘텐츠 권한, DLP=유출경로, TLS/VPN=전송구간.

사진 출처: KakaoTalk_20260816_193027007_05.jpg

5과목

개인정보 관리체계

ISMS-P · 위치정보 · CPO

오답 4/15문항 · 정답률 73.3%

수록 문항: Q89, Q92, Q96, Q97

이 과목은 문장 속 ‘원칙·예외·기준일·주체’를 먼저 표시한 뒤 선지를 판정하세요.

Q89. 다음 중 정보보호 및 개인정보보호 관리체계 인증 (ISMS-P)을 취득할 때, 인증심사의...

정답 결론

제공 정답: ① | 검증 결론: ①

사진 원문 · 지문과 선지

다음 중 정보보호 및 개인정보보호 관리체계 인증(ISMS-P)을 취득할 때, 인증심사의 일부 생략 또는 완화된 기준 적용이 가능한 경우로 적절하지 않은 것은?

- ① ISO/IEC 27001을 취득하였으나 인증 받은 범위 외에 추가되는 시스템에 대해 ISMS-P 인증을 신청하는 경우
- ② 주요정보통신기반시설의 취약점 분석·평가를 완료한 경우
- ③ 교육부 정보보안 기본지침에 따른 정보보안 수준에 대한 해당 연도의 평가결과가 만점의 100분의 80이상인 경우
- ④ 정보통신서비스 부문 매출액이 300억 원 이상인 중기업이 주요 정보통신설비를 직접 설치·운영하지 않은 경우
- ⑤ 「중소기업기본법」 제2조제2항에 따른 소기업이 ISMS-P 인증을 신청하는 경우

STEP BY STEP

- 1 심사 일부 생략은 이미 수행한 공신력 있는 평가와 ISMS-P 신청 범위가 실질적으로 중복될 때 인정된다.
- 2 ISO/IEC 27001 인증을 받았더라도 그 인증범위 밖에 새로 추가되는 시스템은 기존 심사의 증거가 없다.
- 3 따라서 범위 밖 시스템까지 생략할 수 있다고 보는 ①이 부적절하다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	오답(정답 선지) - 기존 ISO 인증범위 밖 시스템은 새로 심사해야 한다.
②	맞음 - 법정 취약점 분석·평가와 중복되는 항목은 요건에 따라 활용될 수 있다.
③	맞음 - 해당 연도 평가결과 등 정해진 요건을 충족하면 일부 완화 근거가 될 수 있다.
④	맞음 - 중기업의 시스템 운영형태 등 정해진 조건에 따라 간소화 적용이 가능하다.
⑤	맞음 - 소기업은 규모에 따른 완화기준 적용 대상이 될 수 있다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.86~89, p.93

심사생략은 '다른 인증이 있다'가 아니라 범위·통제항목·유효기간·평가기관이 겹치는지를 본다. 범위가 다르면 새로 심사한다.

시험장 한 줄 암기
인증은 이름보다 범위가 핵심. 범위 밖 시스템은 생략 불가.

사진 출처: KakaoTalk_20260816_193027007_06.jpg

Q92. 개인위치정보의 이용 또는 제공에 관한 설명으로 적절하지 않은 것을 고르시오.

정답 결론

제공 정답: ⑤ | 검증 결론: ⑤

사진 원문 · 지문과 선지

개인위치정보의 이용 또는 제공에 관한 설명으로 적절하지 않은 것을 고르시오.

- ① 개인위치정보는 위치정보사업자로부터 위치기반서비스사업자로 전송되어 이용·제공되므로, 위치기반서비스사업자가 개인위치정보를 이용·제공하는 경우에는 위치정보사업자가 수집 시 동의 받은 것과는 별도로 동의를 받는 절차가 필요하다.
- ② 개인위치정보를 제3자에게 제공하는 서비스 경우 사전 고지 및 동의와 사후 통보 의무를 함께 규정한다.
- ③ 위치기반서비스사업자는 개인위치정보주체의 동의를 얻어 그가 지정하는 제3자에게 개인위치정보를 제공하는 경우에도 매회 또는 모아서 개인위치정보를 제공받은 제3자, 제공일시, 제공목적을 개인위치정보주체에게 통보하여야 한다.
- ④ 통보 시 원칙은 매회 즉시통보이나 개인위치정보주체의 동의를 받은 경우 최대 30일 범위에서 횟수와 기간 기준에 따라 제3자에 대한 정보제공내역을 모아서 통보할 수 있다.
- ⑤ 통보의 수단은 원칙적으로 위치정보사업자가 개인위치정보를 수집한 서비스의 개인정보 처리방침을 통해 통보해야 한다.

STEP BY STEP

- 1 개인위치정보의 제3자 제공은 사전 동의와 제공 후 통보를 함께 요구한다.
- 2 통보는 원칙적으로 매회 즉시 하며, 동의를 받으면 법정 범위에서 모아서 통보할 수 있다.
- 3 개인정보 처리방침에 일반적으로 적어 두는 것만으로 개별 제공사실 통보를 대신할 수 없으므로 ⑤가 틀렸다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 수집동의와 위치기반서비스의 이용·제공 동의는 역할과 단계가 다르다.
②	맞음 - 사전 고지·동의와 사후 통보가 결합된다.
③	맞음 - 제공받는 자, 제공일시, 제공목적을 통보해야 한다.
④	맞음 - 동의가 있으면 최대 30일 범위에서 모아서 통보할 수 있다.
⑤	오답(정답 선지) - 문자·전자우편·앱 알림 등 실제 통신수단으로 개별 통보해야 하며 처리방침 게시만으로 부족하다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.34, p.92

위치정보 문제는 ‘수집 동의 → 이용약관 명시 → 제3자 제공 동의 → 매회 즉시 통보(또는 동의받은 모아 통보)’의 시간 순서로 외운다.

시험장 한 줄 암기
개인위치정보 제3자 제공 = 사전 동의 + 사후 개별 통보.

사진 출처: KakaoTalk_20260816_193027007_07.jpg

Q96. 개인정보보호법 제31조제1항에 따른 개인정보 보호 책임자 지정에 대한 설명으로 적절하지 ...

검증 경고

제공 정답: 사용자 입력 ③ | 검증 결론: ⑤

검증 경고

사용자 입력 정답 정정. 시행령상 ③의 기관은 4급 이상이 맞고, 시·도 및 시·도 교육청은 3급 이상이므로 ⑤가 틀린 선지다.

사진 원문 · 지문과 선지

개인정보보호법 제31조제1항에 따른 개인정보 보호책임자 지정에 대한 설명으로 적절하지 않은 것을 고르시오.

- ① 국회, 법원, 헌법재판소, 중앙선거관리위원회의 행정사무를 처리하는 기관 및 중앙행정기관 : 고위공무원에 속하는 공무원(이하 '고위공무원') 또는 그에 상당하는 공무원
- ② 정무직공무원을 장(長)으로 하는 국가기관 : 3급 이상 공무원(고위공무원을 포함) 또는 그에 상당하는 공무원
- ③ 고위공무원, 3급 공무원 또는 그에 상당하는 공무원 이상의 공무원을 장으로 하는 국가기관 : 4급 이상 공무원 또는 그에 상당하는 공무원
- ④ ①~③의 국가기관 외의 국가기관(소속 기관을 포함) : 해당 기관의 개인정보 처리 관련 업무를 담당하는 부서의 장
- ⑤ 시·도 및 시·도 교육청 : 4급 이상 공무원 또는 그에 상당하는 공무원

STEP BY STEP

- 1 국가기관의 장 직급에 따라 CPO로 지정할 수 있는 최소 직급이 단계적으로 내려간다.
- 2 고위공무원·3급 이상이 기관장인 국가기관은 4급 이상을 CPO로 지정할 수 있어 ③은 맞다.
- 3 시·도 및 시·도 교육청은 3급 이상 공무원 또는 상당 공무원이 기준이므로 4급이라고 한 ⑤가 틀렸다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 중앙기관 등은 고위공무원 또는 상당 공무원이 기준이다.
②	맞음 - 정무직 기관장은 3급 이상이 기준이다.
③	맞음 - 고위공무원·3급 이상이 장인 국가기관은 4급 이상을 지정할 수 있다.
④	맞음 - 그 밖의 국가기관은 개인정보 업무 담당부서의 장이 기준이다.
⑤	오답(정답 선지) - 시·도 및 시·도 교육청은 4급이 아니라 3급 이상이 기준이다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.25~27

시·군·자치구는 4급 이상, 시·도와 시·도 교육청은 3급 이상으로 구분한다. 이 둘을 바꾸는 선지가 자주 출제된다.

시험장 한 줄 암기

시·도·교육청 3급, 시·군·자치구 4급.

사진 출처: KakaoTalk_20260816_193027007_08.jpg

Q97. 정보보호 및 개인정보보호 관리체계 인증(ISMS-P) 의무 대상자에 대한 설명으로 적절...

정답 결론

제공 정답: ③ | 검증 결론: ③

사진 원문 · 지문과 선지

정보보호 및 개인정보보호 관리체계 인증(ISMS-P) 의무 대상자에 대한 설명으로 적절하지 않은 것을 고르시오.

- ① 정보통신서비스 부문 전년도(법인인 경우에는 전 사업연도를 말한다) 매출액이 100억 원 이상인 자
- ② 「전기통신사업법」 제6조 제1항에 따른 허가를 받은 자로서 서울특별시 및 모든 광역시에서 정보통신망 서비스를 제공하는 자
- ③ 전년도 직전 3개월간 정보통신서비스 일일 평균 이용자 수가 10만 명 이상인 자
- ④ 연간 매출액 또는 세입이 1,500억 원 이상인 자로서 「의료법」 제3조의4에 따른 상급종합병원
- ⑤ 연간 매출액 또는 세입이 1,500억 원 이상인 자로서 직전 연도 12월 31일 기준으로 재학생 수가 1만 이상인 「고등교육법」 제2조에 따른 학교

STEP BY STEP

- 1 ISMS 인증 의무대상은 ISP·IDC와 일정 규모 이상의 정보통신서비스 제공자, 상급종합병원·학교 등으로 나뉜다.
- 2 이용자 수 기준은 전년도 일일평균 100만 명 이상이다.
- 3 ③은 10만 명이라고 하여 기준을 10분의 1로 줄였으므로 틀렸다.

선지별 판정

선지	왜 맞고 / 왜 틀리는가
①	맞음 - 정보통신서비스 부문 전년도 매출 100억 원 이상 기준이 있다.
②	맞음 - 법이 정한 ISP 범주다.
③	오답(정답 선지) - 기준은 10만 명이 아니라 전년도 일일평균 100만 명 이상이다.
④	맞음 - 매출·세입 1,500억 원 이상 상급종합병원 기준이 있다.
⑤	맞음 - 매출·세입과 재학생 수 기준을 함께 충족하는 학교가 포함된다.

예랑이랑 통합본 연결 · 추가 보강

관련 페이지: p.86~89, p.93

의무대상자는 ISMS 또는 ISMS-P 중 선택해 인증할 수 있다. 'ISMS-P만 의무'라고 단정하지 말고 의무대상 범위와 선택구조를 구분한다.

시험장 한 줄 암기
ISMS 이용자 수 기준은 10만이 아니라 100만.

사진 출처: KakaoTalk_20260816_193027007_09.jpg

공식 근거 · 학습 자료

- 개인정보 보호법

<https://www.law.go.kr/LSW/lsInfoP.do?lsiSeq=270351>

- 개인정보 보호법 시행령

<https://www.law.go.kr/LSW/lsInfoP.do?ancYnChk=0&chrClsCd=010202&efYd=20260519&lsiSeq=286175&urlMode=lsInfoP>

- 개인정보의 안전성 확보조치 기준(2026-9호)

<https://www.law.go.kr/LSW/admRulInfoP.do?admRulSeq=2100000281400&chrClsCd=010201>

- 개인정보 국외이전 제28조의8

<https://www.law.go.kr/LSW/lsLinkCommonInfo.do?chrClsCd=010202&lsJoLnkSeq=1029334953>

- 전자상거래법 시행령 기록보존

<https://www.law.go.kr/LSW/lsInfoP.do?lsiSeq=200509>

- KISA ISMS-P 인증대상

<https://isms.kisa.or.kr/main/ispims/target>

- 위치정보법

<https://www.law.go.kr/LSW/lsInfoP.do?lsiSeq=160154>

- 예랑이랑 CPPG 통합본

C:\동현\cppg\2026_예랑이랑_CPPG_통합본.pdf-20260512160233.pdf

자료 사용 메모

첨부한 40장의 사진에서 지문과 선지를 전사했습니다. ‘예랑이랑’ PDF는 관련 개념과 암기 구조를 보강하는 데 사용했으며 원문 전체를 복제하지 않았습니다. 법령·고시는 검증 기준일 현재 시행 내용을 우선했습니다.

마지막 점검 습관

숫자를 외우기 전에 ① 누구에게 ② 어떤 정보에 ③ 어떤 행위에 ④ 언제 시행되는 기준인지 확인하세요.